



网络安全技术及应用

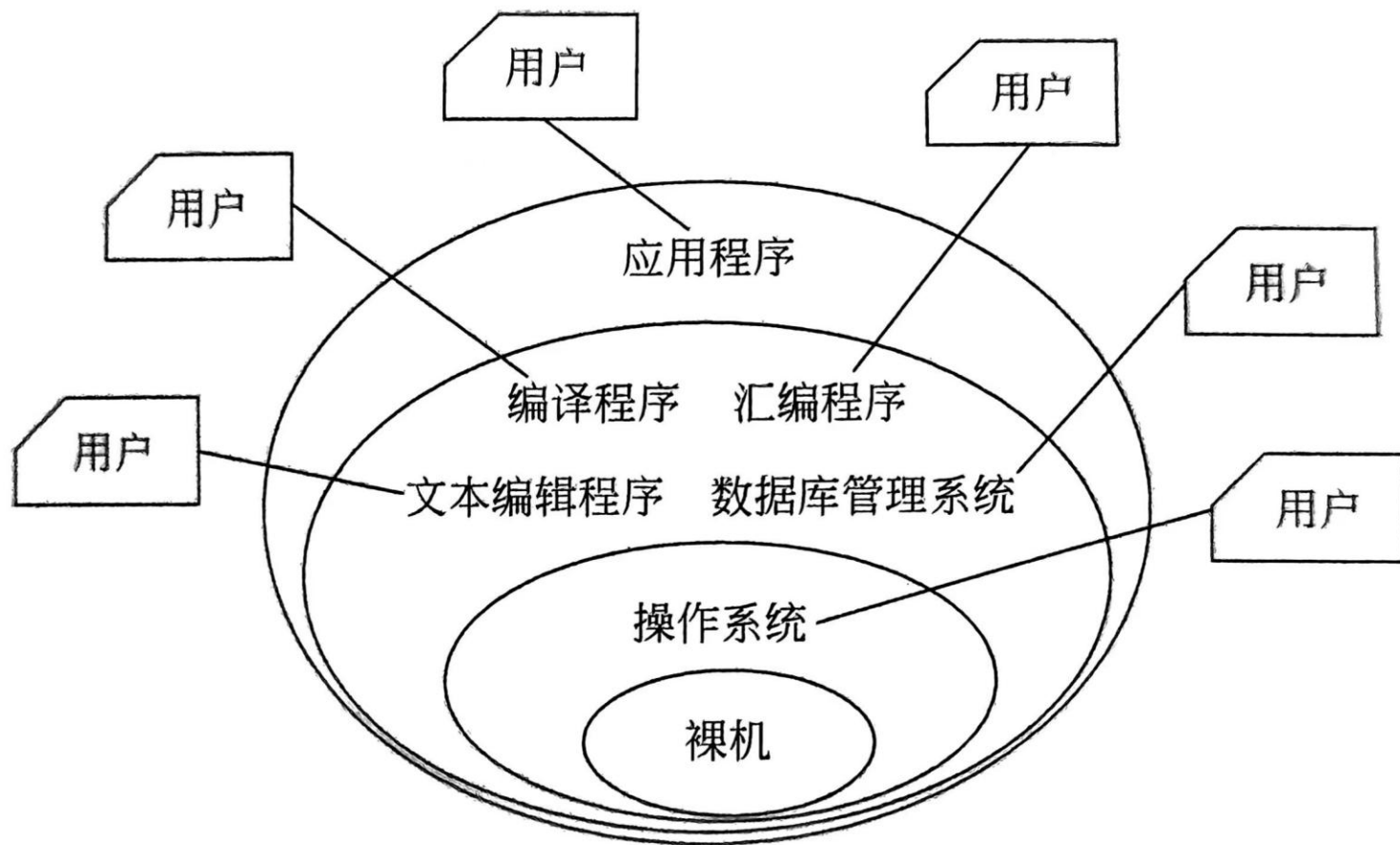
(第5版, 慕课微课版, 新形态)

贾铁军 何道敬 罗宜元 主编
古乐声 王威 张书台 副主编
王坚 陈国秦 参编

 机械工业出版社
CHINA MACHINE PRESS

第11章 电子商务安全

回顾

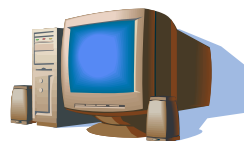


计算机系统的组成

第11章 电子商务安全

第11章 目录

- 1 11.1 电子商务安全基础
- 2 11.2 电子商务的安全技术和交易
- 3 11.3 构建基于SSL的Web安全站点
- 4 11.4 电子商务安全解决方案
- 5 11.5 AI技术在电子商务中的安全
- 6 11.6 物联网设备安全问题与防范
- 7 11.7 本章小结
- 8 *11.8实验11应用工具软件分析网站日志



第11章 电子商务安全

□教学目标

- 理解电子商务安全的相关概念和内容 **重点**
- 掌握电子商务常用的SSL、SET安全协议
- 了解基于SSL协议Web 服务器的构建方法
- 学会Android应用漏洞的具体检测方法





11.1 电子商务安全基础

11.1.1 电子商务及安全风险

电子商务安全是网上交易的首要条件和保障。伴随着互联网的快速发展，电子商务的应用范围越来越广，日益成为主流商务模式和经济活动。在电子商务交易过程中，如果出现信息安全问题，必然会影响交易安全。中国是全球规模最大、最具活力的电子商务市场，电子商务销售额和网购消费人数均排名全球第一。重视电子商务安全应用的环境和技术方法, 已经成为电子商务企业和用户共同关注的热点问题。



11.1 电子商务安全基础

11.1.1 电子商务及安全风险

案例11—1

【引导案例】商务数据泄露：2021年6月3日，商丘市睢阳区人民法院在裁判文书网，公开了一份刑事判决书，显示一名住在河南商丘市的本科毕业的大学生逯某自2019年11月起，对淘宝实施了长达八个月的数据爬取并盗走大量用户数据。在阿里巴巴注意到这一问题前，已经有超过11亿8千多万条用户信息泄露。

电子商务是政府、企业和个人利用计算机、平板电脑或手机等智能电子设备，依赖网络通信技术完成商业活动的全过程，是一种基于互联网或专用网络，以参与交易的各方为主体，以金融机构电子支付和非现金结算为手段，以客户数据为依托的商务模式。**电子商务**是集企业管理信息化、金融电子化、商贸信息网络化和物流全球化为一体，旨在实现信息流、现金流和实物流的流动成本最小化，效率和效益最大化的现代贸易方式。



11.1 电子商务安全基础

11.1.1 电子商务及安全风险

电子商务作为新兴的商业运作模式，帮助全球企业和个人用户突破时间和空间的制约，提供了多样化的资讯，缩短了交易流程，并降低了交易成本。但如果不能保证电子商务的交易安全，就会违背公平、公正和公开的交易原则，损害合法交易人的利益，增加交易成本，甚至给交易各方带来无法估量的经济损失。

电子商务的安全问题是电子商务发展过程中始终关注的重要课题。电子商务的安全实用技术，就是通过综合的技术手段和管理手段借助安全保密技术和法律法规体系，防范化解交易过程中的各种风险，保证网上交易的顺利实施。

11.1 电子商务安全基础

11.1.1 电子商务及安全风险

电子商务威胁实例

● 数据泄露

1. 雅虎数据泄露事件：**2013** 年雅虎遭受了规模空前的数据泄露，约 **3** 亿用户账户受影响，黑客通过攻击其电子邮件服务器窃取了用户名、密码、安全问题及答案等用户个人信息，给用户带来了隐私风险。
2. 京东用户数据泄露事件：**2017** 年京东曝出用户数据泄露事件，黑客攻击京东的供应链系统，获取了大量用户的个人信息，京东虽公开道歉并加强数据安全保护，但声誉仍受损。

● 黑客攻击

1. 英国 **CloudNine** 网站被攻击破产：**2012** 年英国电商网站 **CloudNine** 遭受黑客攻击，导致网站一直无法恢复运营，最终宣布破产，由其竞争对手 **Zetnet** 接管剩余事务，这使它成为英国第一家因黑客攻击而破产的电子商务公司。
2. 义乌大型批发网站遭攻击：浙江义乌一些大型批发网站曾遭到黑客近一个月的轮番攻击，网站图片几乎都不能显示，每天流失订单金额达上百万元。



11.1 电子商务安全基础

11.1.1 电子商务及安全风险

电子商务威胁实例

- 网络钓鱼攻击

仿冒网站窃取用户信息：钓鱼网站仿冒真实电商网站，用户在不知情的情况下在这些假冒网站上输入个人信息，如用户名、密码、信用卡号等，导致信息泄露，进而遭受经济损失，还可能使用户对电子商务平台的信任度下降。

- 错价及交易异常

淘宝“错价门”事件：淘宝网上曾出现大量商品标价 1 元的情况，引发网民哄抢，之后许多订单被取消。淘宝发布公告称是第三方软件“团购宝”交易异常所致，部分客服称服务器可能被攻击，该事件暴露出我国电子商务安全问题，也引发了关于淘宝网关闭交易行为合法性的争议。

- 内部人员作案

1 号店员工泄露客户信息：1 号店曾发生员工内外勾结泄露客户信息的事件，员工利用职务之便获取并出售用户个人信息，给用户带来了安全隐患和损失。

11.1 电子商务安全基础

11.1.2 电子商务安全的概念和内容

案例11-2

全球经济复苏，电子商务增长回暖：2021年，全球经济开始从新冠疫情的早期影响中复苏，全球电子商务同比增长14%，交易额超过5.3万亿美元。预计到2025年，全球电子商务复合年均增长率将达到12%，届时总额将超过8.3万亿美元。在新冠疫情的持续影响以及市场趋向成熟的综合作用下，预计亚太地区的电子商务增长将放缓，但拉丁美洲地区以及中东和非洲地区仍将持续大幅增长，到2025年，复合年均增长率分别为19%和20%。

1. 电子商务安全的概念

电子商务安全是指通过采取各种**安全技术措施**，建立有效的**技术防御体系**和管理机制，保障电子商务活动中网络系统传输、交易流程、支付过程和相关数据的**安全**。**保证交易数据的安全**是电子商务安全的**关键**。电子商务安全涉及很多方面，不仅与网络系统结构和监控管理有关，而且与电子商务具体应用的软硬件环境、人员素质、法制法规和管理等因素有关。

11.1 电子商务安全基础

11.1.2 电子商务安全的概念和内容

2. 电子商务安全的主要内容

电子商务的安全技术，主要涵盖五方面内容。

1) **连接访问控制**:指保证只有授权方才能与网络设备建立关联，访问服务器端资源；访问控制也同时使合法用户具有访问特定资源的权限。连接访问控制是安全技术的第一道防线，可以阻止非授权用户建立连接，并阻止所有消息从非授权源到达目的地。

2) **数据来源认证**:是指授权方成功建立安全关联后，入侵者可能通过在有关通信的任意一个源头插入伪造消息的方式进行渗透和劫持。**数据来源认证**通过确认接收的消息确定来源于发送方，从而阻止这种攻击，这种技术可以用于所有关联交易的消息交换过程。



11.1 电子商务安全基础

11.1.2 电子商务安全的概念和内容

2. 电子商务安全的主要内容

电子商务的安全技术，主要涵盖五方面内容。



3) **数据完整确认**，数据来源认证保证了所接收的消息来源于合法的发送方，但是不能保证数据在传送过程中没有遭到篡改。入侵者可能通过物理接入传送线路的方法窃听消息并篡改部分或全部消息。**数据完整确认的目的**是检测消息是否被篡改，其中包括消息内容的部分或全部，消息内容的前后顺序以及消息发送的时间是否被提前或拖后等。

4) **内容机密性认证**，有时入侵者不是为了篡改消息，而是为了提前或非法获取机密消息，并且隐藏自己已经提前获知该消息的事实。数据完整性认证可以保证数据原封不动传送到目的端，但无法保证在传送过程中没有被第三方窥视或揭封。**内容机密性认证**需要保证消息发送的时间、长度以及消息的内容均处于机密状态。

11.1 电子商务安全基础

11.1.2 电子商务安全的概念和内容

2. 电子商务安全的主要内容

电子商务的安全技术，主要涵盖以下五方面的内容。

5) 安全预警和审计稽核。当电子商务的安全潜在或正在遭受威胁时，安全系统模块需要预先或及时发出警报指示。而安全日志记录和跟踪电子商务整个流转过程中的操作痕迹，通过完善的审计稽核制度来检测是否有入侵者获取或篡改交易数据，提供证据化解纠纷，预警、阻止和判断网络犯罪。



11.1 电子商务安全基础

11.1.3 电子商务的安全要素

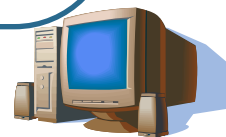
1. 电子商务的安全要素

电子商务安全的要素概括六方面的内容。

真实性网上交易双方身份和交易信息真实有效;**保密性**信息传输过程或存储、密码技术;**完整性**防止非法篡改和破坏;**存储安全及不可否认性**。其他要素:**可靠性**:防止服务器出错,硬件,软件。**有效性**:服务器能为用户提供稳定的服务。**及时性**:服务器能提供给用户所需的服务性能。

(1) 商业信息的机密性

电子商务作为一种贸易的手段,其交易信息直接涉及用户个人、企事业单位或国家的商业机密。传统的纸面贸易都是通过邮寄封装的信件或通过可靠的通信渠道发送商业报文达到保守机密的目的。电子商务建立在一个开放的网络环境中,维护商业机密是电子商务全面推广应用的重要保障。因此,必须预防非法的信息存取和信息在传输过程中被非法窃取。



11.1 电子商务安全基础

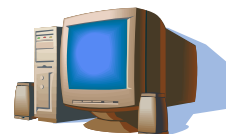
11.1.3 电子商务的安全要素

1. 电子商务的安全要素

电子商务安全的要素概括六方面的内容。

(2) 交易数据的完整性

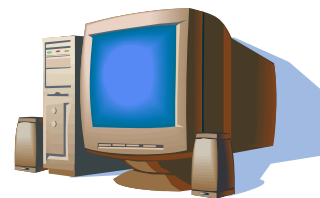
主要防范对业务数据信息的随意生成、篡改或删除，同时要防止数据传输过程中信息的丢失和重复。电子商务简化了贸易过程，减少人为的干预，同时也带来维护贸易各方商业信息的完整和一致的问题。由于数据输入时的意外差错或欺诈行为，可能导致贸易各方信息的差异。此外，数据传输过程中信息丢失、信息重复或信息传送的次序差异也会导致贸易各方信息的不同。贸易各方信息的完整性将影响到贸易各方的交易和经营策略，保持贸易各方信息的完整性是电子商务应用的基础。因此，要预防对信息的随意生成、修改和删除，同时要防止数据传送过程中重要信息的丢失和重复并保证信息传输次序的一致。



11.1 电子商务安全基础

11.1.3 电子商务的安全要素

1. 电子商务的安全要素



电子商务安全的要素概括六方面的内容。

(3) 商务系统的可靠性

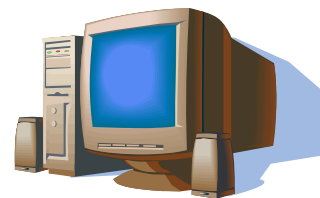
商务系统的可靠性主要指交易者身份的确定。电子商务可能直接关系到贸易双方的商业交易，如何确定要进行交易的贸易方正是进行交易所期望的贸易方，这一问题则是保证电子商务顺利进行的关键。在传统的纸面贸易中，贸易双方通过在交易合同、契约或贸易单据等书面文件上手写签名或印章来鉴别贸易伙伴，确定合同、契约和单据的可靠性并预防抵赖行为的发生。在无纸化的电子商务方式中，通过手写签名和印章进行贸易方的鉴别已不可能，因此，要在交易信息的传输过程中为参与交易的个人、企业或国家提供可靠的标识。

11.1 电子商务安全基础

11.1.3 电子商务的安全要素

1. 电子商务的安全要素

电子商务安全要素概括六方面的内容。



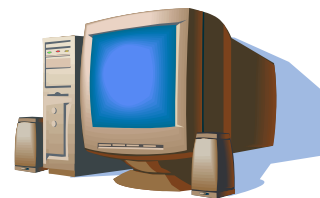
(4) 交易数据的有效性

保证贸易数据在确定的时间、指定的地点为有效的。电子商务以电子形式取代了纸张，如何保证这种电子形式贸易信息的有效性则是进行电子商务的前提条件。电子商务作为贸易的一种形式，其信息的有效性将直接关系到个人、企业或国家的经济利益和声誉。因此，必须对网络故障、操作错误、应用程序错误、硬件故障、系统软件错误及计算机病毒所产生的潜在威胁加以控制和预防，以保证贸易数据在确定的时刻、指定的地点是有效的。

11.1 电子商务安全基础

11.1.3 电子商务的安全要素

1. 电子商务的安全要素



电子商务安全要素概括六方面的内容。

(5) 商业交易的不可否认性

电子交易的不可否认性也称不可抵赖性或可审查性，以确定电子合同、交易和信息的可靠性与可审查性，并预防可能的否认行为的发生，不可抵赖性包括：

- 1) 源点防抵赖，使信息发送者事后无法否认发送了信息。
- 2) 接收防抵赖，使信息接收方无法抵赖接收到了信息。
- 3) 回执防抵赖，发送责任回执的各环节均无法推卸其应负责任。

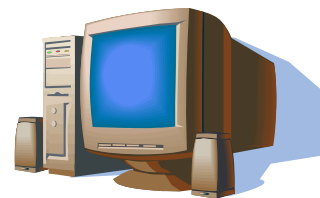
为了满足电子商务的安全要求，电子商务系统必须利用安全技术为其活动参与者提供可靠的安全服务，主要包括：鉴别服务、访问控制服务、机密性服务、不可否认服务等。鉴别服务是对贸易方的身份进行鉴别，为身份的真实性提供保证；访问控制服务通过授权对使用资源的方式进行控制，防止非授权使用资源或控制资源，有助于贸易信息的机密性、完整性和可控性；机密性服务的目标为电子商务参与者信息在存储、处理和传输过程中提供机密性保证，防止信息被泄露给非授权信息获取者；不可否认服务针对合法用户的威胁，为交易的双方提供不可否认的证据，来解决因否认而产生的争议提供支持。

11.1 电子商务安全基础

11.1.3 电子商务的安全要素

1. 电子商务的安全要素

电子商务安全的要素概括六方面的内容。



(6) 隐私性

在交易流在电子交易的过程中会产生各种各样的个人信息安全问题，商家和用户的个人信息和隐私应该得到保护。电子商务系统必须在确保交易对象的真实性和安全性的同时，提供交易平台的隐私性，防止交易过程被跟踪、交易对象被锁定，保证交易过程中不把交易各方的个人信息泄漏给未知的或不可信的个体，以保护合法用户的隐私不被侵犯。

11.1 电子商务安全基础

11.1.3 电子商务的安全要素

2. 电子商务应用中的安全协议及规范

电子商务应用中的安全协议和规范主要有四种。



1) 安全超文本传输协议（**S-HTTP**）

依靠密钥对加密，可以保障Web站点间的交易信息传输的安全性。

2) 安全套接层协议**SSL**（**Secure Sockets Layer**）

由 Netscape 公司提出的安全交易协议，提供加密、认证服务和报文的完整性。SSL被用于 Netscape Communicator 和 Microsoft IE浏览器，以完成安全交易操作。（传输层安全协议TSL）

11.1 电子商务安全基础

11.1.3 电子商务的安全要素

2. 电子商务应用中的安全协议及规范

电子商务应用中的安全无协议和规范主要有四种。



3) 安全交易技术协议**STT** (Secure Transaction Technology)

微软公司在IE浏览器中采用的技术，**STT** 将认证和解密在浏览器中分离，用以提高安全控制能力。用软件数字证书代替塑料卡片上的磁条信息，将支付凭证加密后嵌在交易报文中。

4) 安全电子交易**SET**协议 (Secure Electronic Transaction)

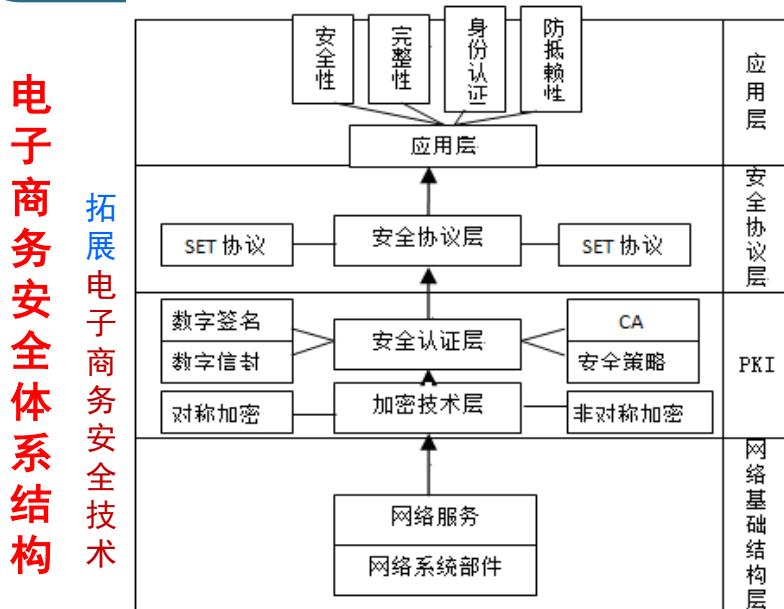
协议、UN/ EDIFACT的安全等。多方证书体系和双重签名。

11.1 电子商务安全基础

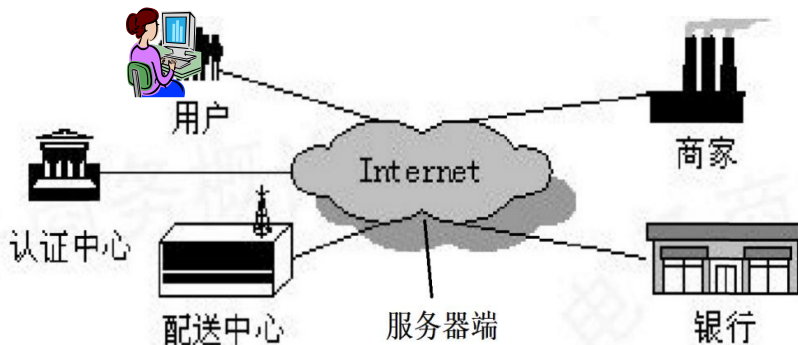
11.1.4 电子商务的安全体系

电子商务安全体系是一庞大而复杂结构不仅包括安全基础设施、安全和加密技术、交易技术协议、安全支付机制等技术领域的体系基础，而且涉及行业自律、政府监管、意识形态、法律法规等管理领域的上层建筑。

一个相对完整的电子商务安全体系由网络基础设施层、PKI体系结构层、安全协议层、安全应用技术层、行为控制管理层和安全立法层6部分组成。通过此体系，有效组织和实施电子商务安全系统的管理规划、设计、监控和决策，并保证在最佳安全状态下正常高效运转。



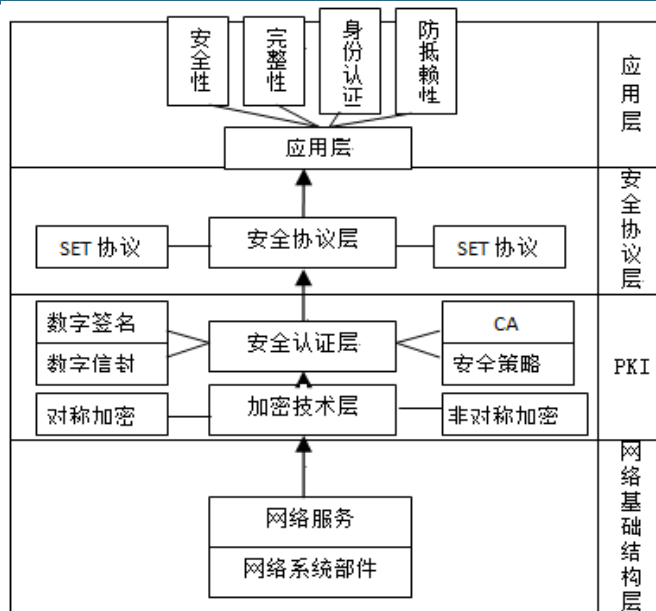
[拓展]电子商务体系包括5部分：服务器端、银行端、客户端、认证机构和商家。**认证机构是安全关键。**



11.1 电子商务安全基础

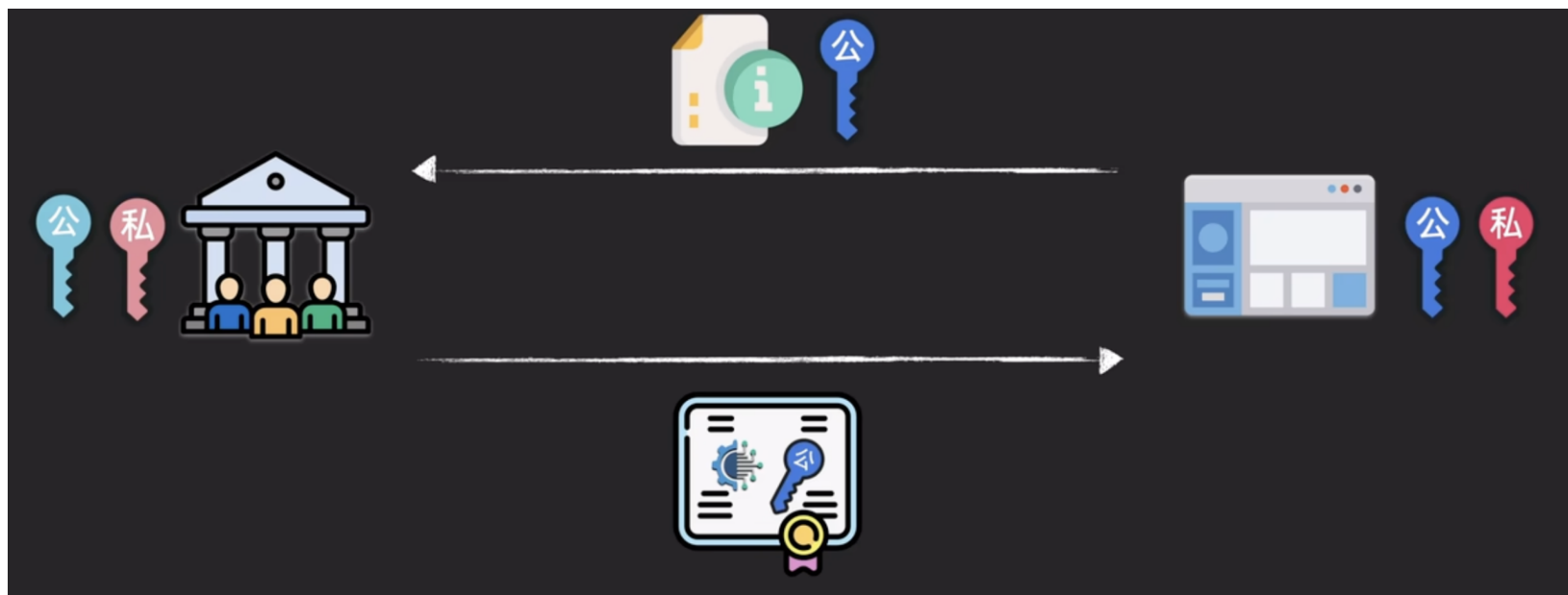
11.1.4 电子商务的安全体系

通过建立完善的电子商务安全体系，可以有效组织和实施电子商务安全系统的**管理规划、设计、监控和决策**，同时又是保证电子商务系统在最佳安全状态下正常高效运转的关键一环。**PKI (Public Key Infrastructure, 公钥基础设施)**是一种遵循标准的利用公钥加密技术为电子商务的开展提供一套安全基础平台的技术和规范。其中，**下层**是上层的基础，为上层提供相应的技术支持。**上层**是下层的扩展与递进，各层次之间相互依赖、相互关联构成统一整体。通过不同的安全控制技术，实现各层的安全策略，保证电子商务系统的安全。



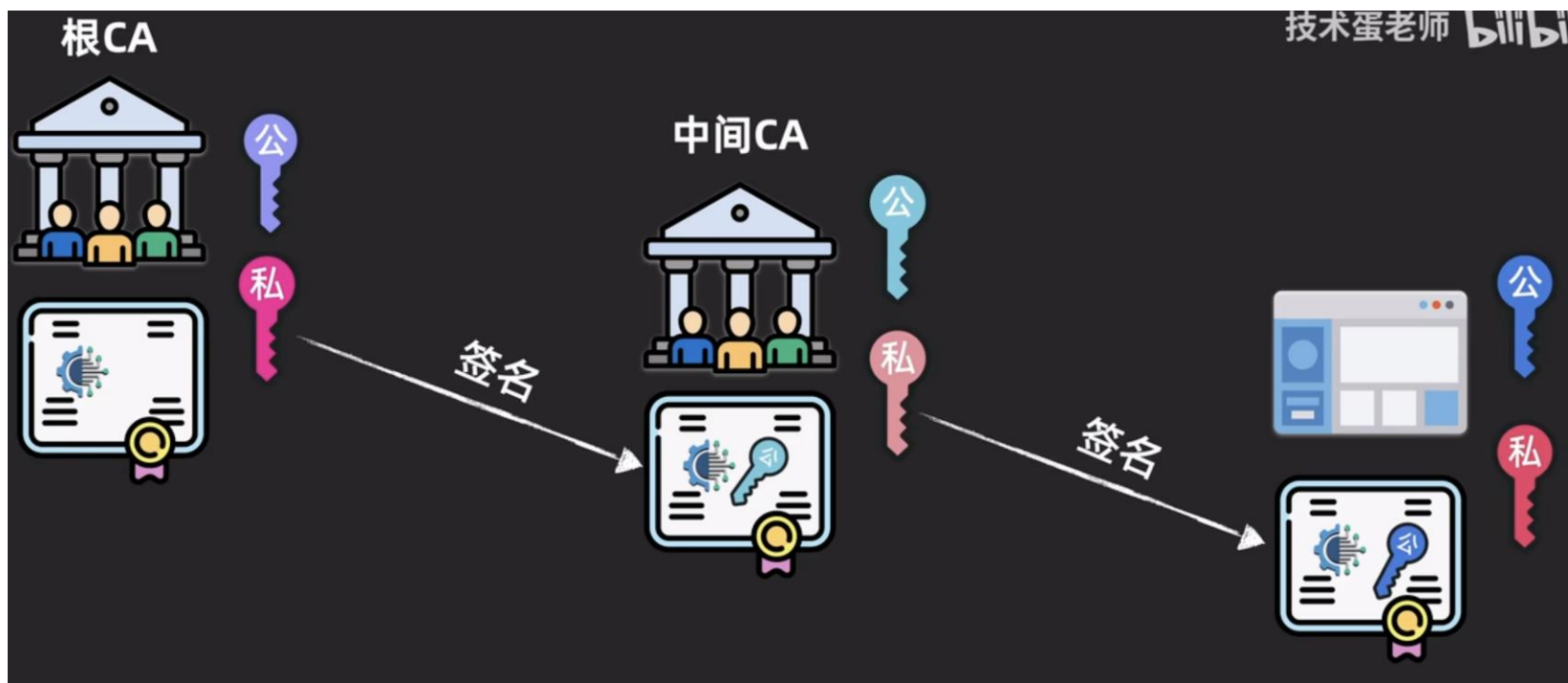
6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术



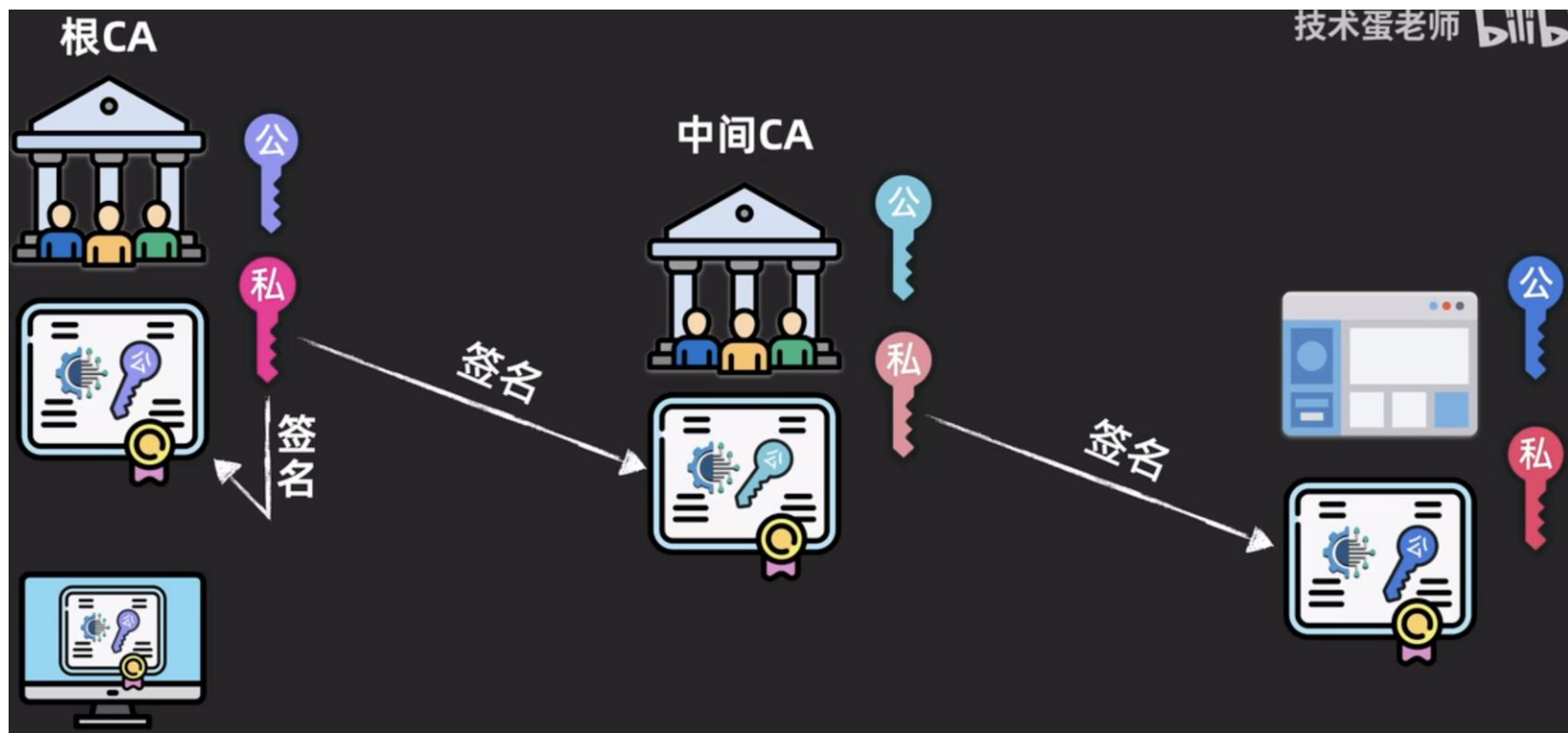
6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术



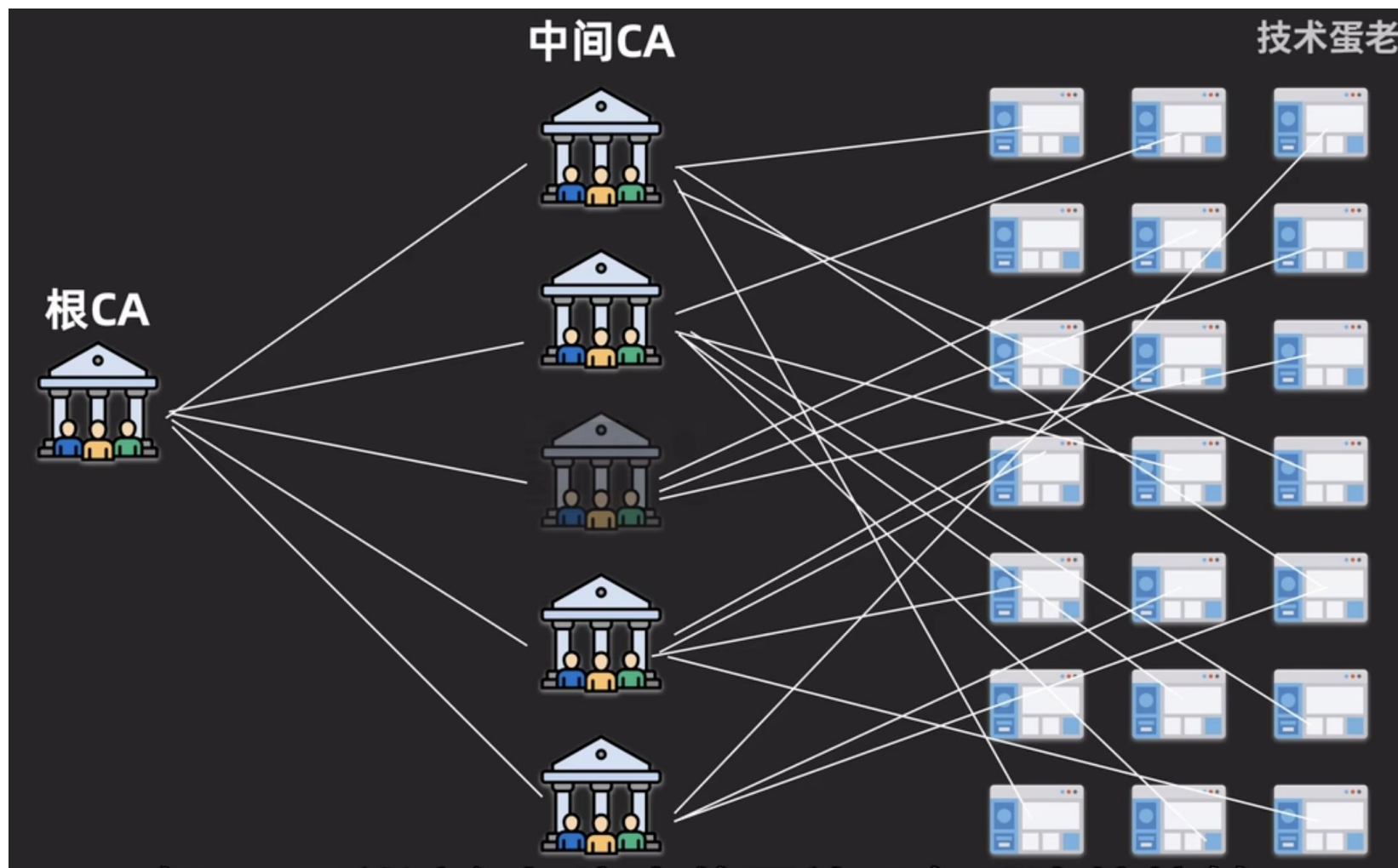
6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术



6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术



11.1 电子商务安全基础

11.1.4 电子商务的安全体系

电子商务的法律基础

1. 电子合同法

1999年10月实施的《中华人民共和国合同法》第十一条规定，“书面形式是指合同书、信件和数据电文(包括电报、电传、传真、**电子数据交换和电子邮件**)等可以有形地表现所载内容的形式。”这是我国法律首次规定了**数据电文可以作为书面形式用于合同的签订**。

2. 电子签名制度

《中华人民共和国电子签名法》于**2005年4月1日**起正式实施，它是我国电子商务领域的第一部法律。《电子签名法》规定了电子签名具有与手写签名或者盖章同等的法律效力，同时承认电子文件与书面文件具有同等效力。

3. 域名法律保护

2002年中国互联网络信息中心依据**ICANN**（互联网名称与数字地址分配机构）的《统一域名争议解决规则》的基本精神，结合我国实际情况制定了《中国互联网络信息中心域名争议解决办法》，并自此确立了我国的域名保护法律机制。

(https://blog.csdn.net/weixin_37813152/article/details/132193270)



11.1 电子商务安全基础

11.1.4 电子商务的安全体系

4. 电子商务法

《中华人民共和国电子商务法》(《电子商务法》)自**2019年1月1日**起施行,这是中国第一部电子商务领域的**综合性**法律。《电子商务法》是一部调整消费者、平台、入驻经营者利益法律关系的民事立法。

☺讨论思考:

- 1) 举例说明电子商务遭受安全威胁的实例?
- 2) 电子商务的安全主要与哪些因素有关?
- 3) 电子商务的安全体系主要包括哪些方面?



11.2 电子商务的安全技术和交易

随着电子商务的广泛应用，网络安全技术和交易安全也不断得到发展完善，特别是近几年多次出现的安全事故引起了国内外的高度重视，计算机网络安全技术得到大力加强和提高。安全核心系统、**VPN** 安全隧道、身份认证、网络底层数据加密和网络入侵监测等技术得到快速发展，可以从不同层面加强计算机网络的整体安全性。



11.2 电子商务的安全技术和交易

11.2.1 电子商务的安全技术

网络安全核心系统在实现一个完整或较完整的安全体系的同时也能与传统网络协议保持一致，它以密码核心系统为基础，支持不同类型的安全硬件产品，屏蔽安全硬件的变化对上层应用的影响，实现多种网络安全协议，并以此为基础提供各种安全的商务业务和应用。

一个**全方位**的**网络安全体系结构**包含网络的物理安全、访问控制安全、用户安全、信息加密、安全传输和管理安全等。在攻击者和受保护的资源间建立多道严密的安全防线，可以极大提高恶意攻击的难度，并通过审核信息量，对入侵者进行跟踪。

常用的**网络安全技术**包括：电子安全交易技术、硬件隔离技术、数据加密技术、认证技术、安全技术协议、安全检测与审计、数据安全技术、防火墙技术、计算机病毒防范技术以及网络商务安全管理技术等。其中，涉及网络安全技术方面的内容，前面已经进行了具体介绍，下面重点介绍**网上交易安全协议**和**网络安全电子交易(SET)**等电子商务安全技术。



11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

电子商务应用的核心和关键问题是交易的安全性。由于互联网的开放性，使得网上交易面临着多种风险，需要提供安全措施。近年来，信息技术行业与金融行业联合制定了一些安全交易标准，主要包括 SSL标准和 SET 标准等。

11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

1. 安全套接层协议SSL



安全套接层协议(Secure Sockets Layer, SSL)为一种传输层技术,主要用于实现兼容浏览器和Web 服务器之间的安全通信。SSL 协议是目前网上购物网站中经常使用的一种安全协议。使用它在于确保信息在网际网络上流通的安全性,让浏览器和Web 服务器能够安全地进行沟通。

其实SSL 就是在和对方通信前预先协商好的一套方法,这套方法能够在双方之间建立一个电子商务的安全性秘密信道,确保电子商务的安全性,凡是不希望被别人看到的机密数据,都可通过这个秘密信道传送给对方,即使通过公共线路传输,也不必担心别人的偷窥。**SSL 为快速架设商业网站提供比较可靠的安全保障,并且成本低廉,容易架设。**



11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

2. SSL提供的服务

SSL标准主要提供3种服务：数据加密服务、认证服务与数据完整性服务。

(1) 数据加密服务。SSL 标准采用的是对称加密技术与公开密钥加密技术。SSL客户机与服务器进行数据交换之前，首先需要交换SSL 初始握手信息，在SSL 握手时采用加密技术加密，保证数据在传输过程中不被截获与篡改。

(2) 用户身份认证服务。SSL 客户机与服务器都有各自的识别号，这些识别号使用公开密钥进行加密。在客户机与服务器进行数据交换时，SSL 握手需要交换各自的识别号，以保证数据被发送到正确的客户机或服务器上。

(3) 数据完整性服务。它采用哈希函数和机密共享的方法提供完整信息性的服务，在客户机与服务器之间建立安全通道，以保证数据在传输中完整到达目的地。

11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理

SSL 标准的工作流程主要包括：SSL 客户机向SSL 服务器发出连接建立请求，SSL 服务器响应SSL 客户机的请求；SSL 客户机与SSL 服务器交换双方认可的密码，一般采用的加密算法是RSA 算法；检验SSL 服务器得到的密码是否正确，并验证SSL 客户机的可信程度；SSL 客户机与SSL 服务器交换结束的信息。图11-2 所示是SSL 标准的工作流程。

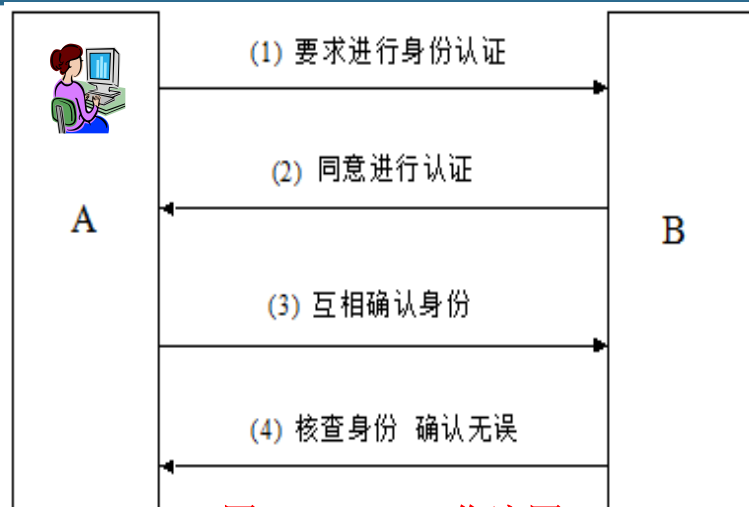


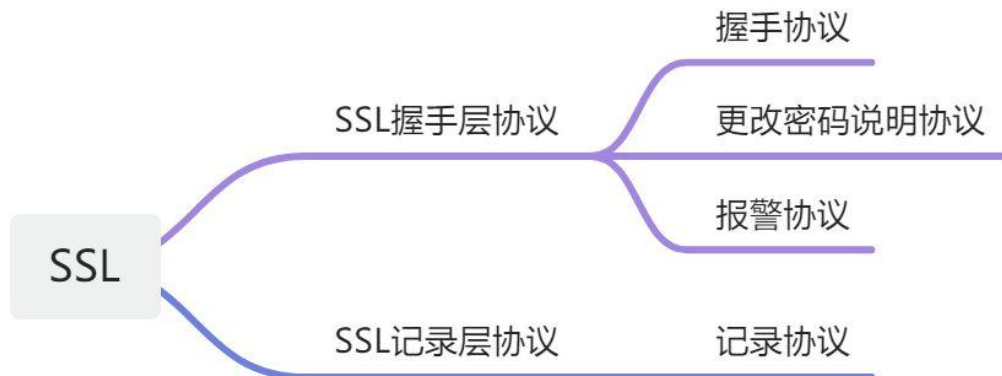
图11-2 SSL工作流程图



11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理



SSL握手协议	SSL告警协议	SSL修改密文协议	应用数据协议 HTTP、FTP、Telnet等
SSL记录协议			
TCP			
IP			

11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理

两个状态：连接状态、会话状态

会话状态要素：会话标识符；对方证书；压缩方法；密码规范；主密码；可重用否

连接状态要素：服务器和客户端的随机数；服务器写MAC密码；客户端写MAC密码；服务器写密钥；客户端写密钥；初始向量；序列号

通信步骤：建立TCP连接；SSL握手，建立SSL会话；通过会话传送加密数据包；释放连接，会话过期

11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理——SSL握手协议

握手协议被封装在记录协议中，该协议允许服务器与客户机在应用程序传输和接受数据之前互相认证、协商加密算法和密钥。在初次建立SSL连接时服务器与客户机交换一系列信息。

SSL握手协议报文头包括三个字段：

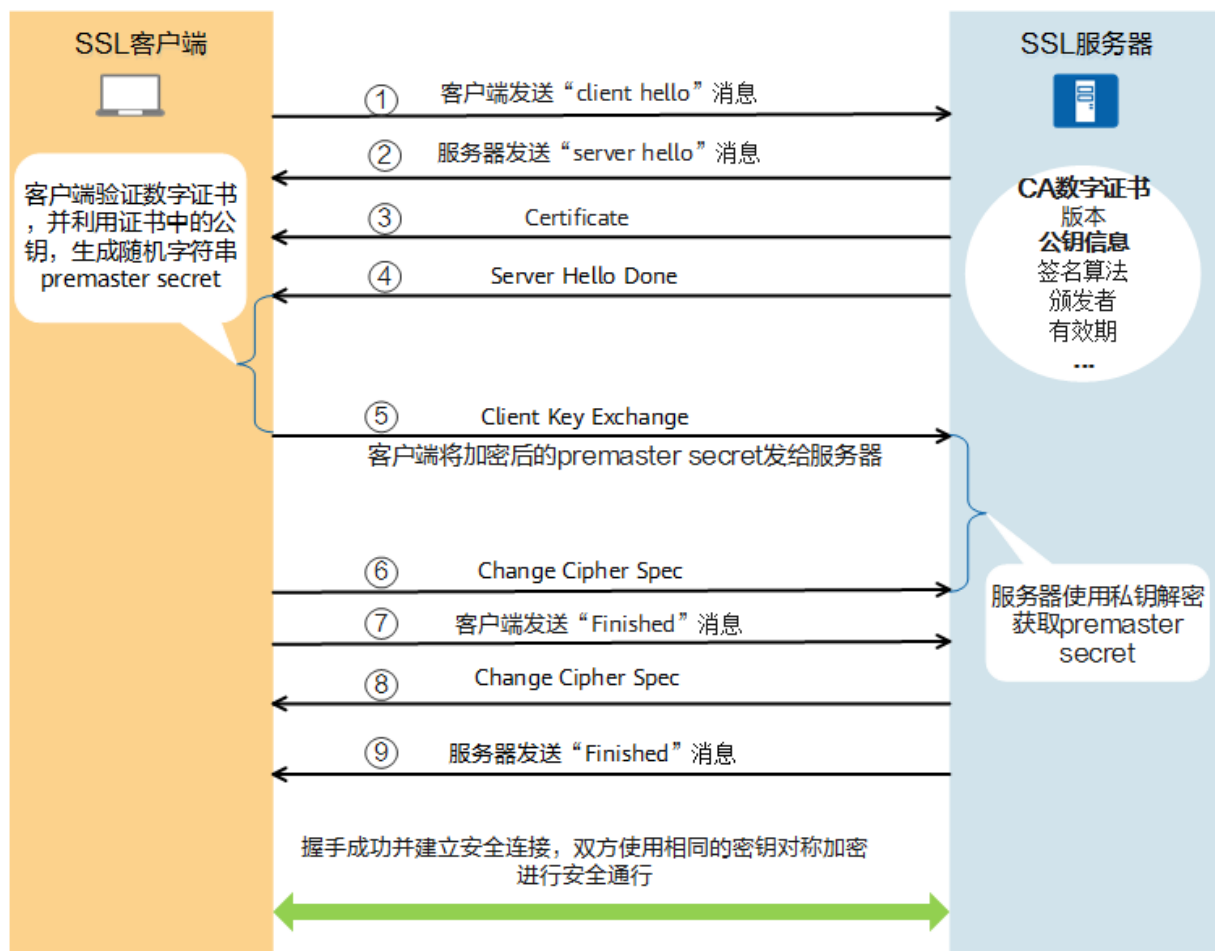
1. 类型(1字节)：该字段指明使用的SSL握手协议报文类型。
2. 长度(3字节)：以字节为单位的报文长度。
3. 内容(≥1字节)：使用的报文的有关参数。

报文类型	参数
hello_request	空
client_hello	版本、随机数、会话 ID、密文族、压缩方法
server_hello	版本、随机数、会话 ID、密文族、压缩方法
certificate	X.509v3 证书链
server_key_exchange	参数、签名
certificate_request	类型、授权
server_done	空
certificate_verify	签名
client_key_exchange	参数、签名
finished	Hash 值

11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理——SSL握手协议

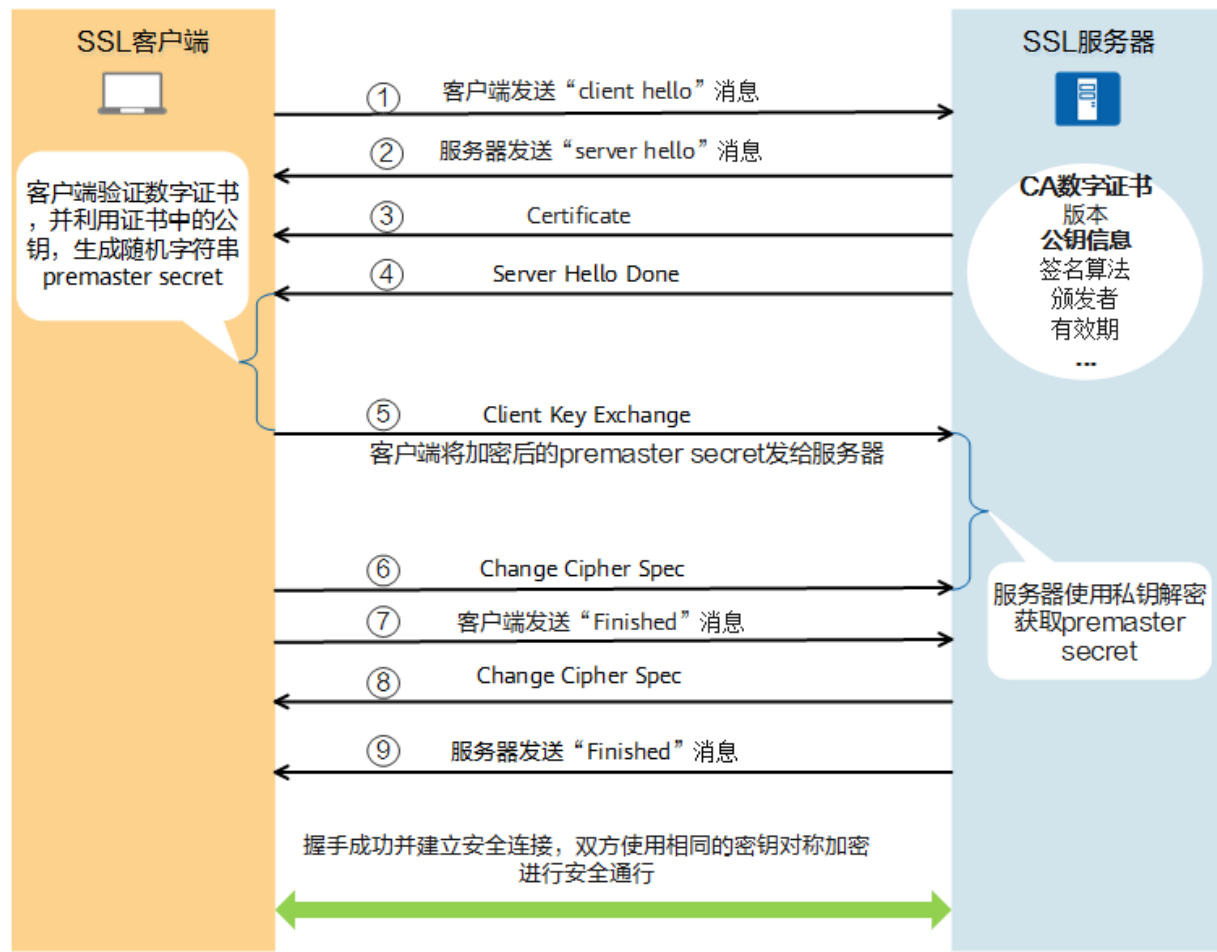


11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理——SSL握手协议

当一SSL客户和服务
器首次开始通信时，
就协议版本、加密
算法的选择、是否验
证对方及公钥加密技
术的应用进行协商以
产生共享的秘密，这
一处理是由握手协议
完成的。

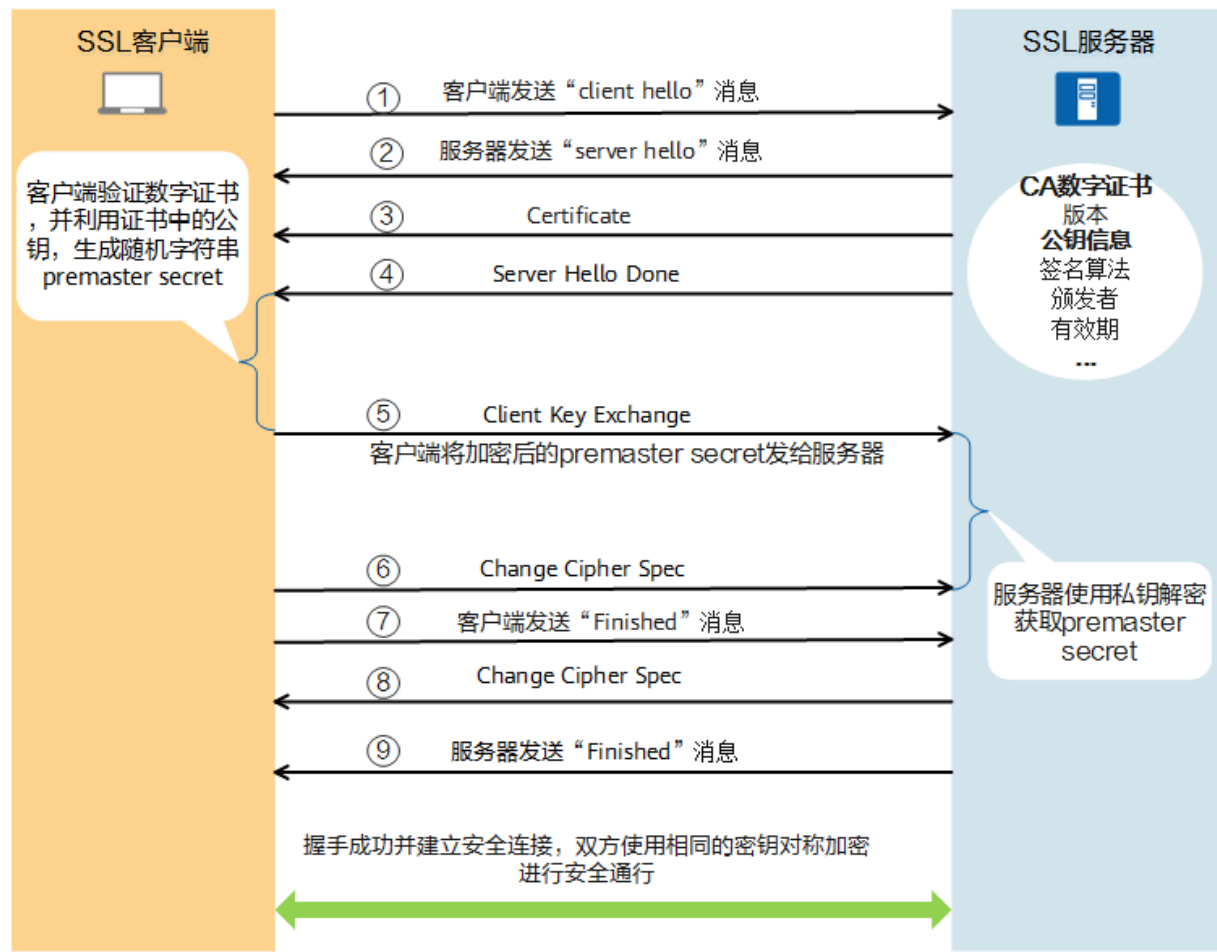


11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理——SSL握手协议

1. 建立安全能力：客户机向服务器发送client hello报文，服务器向客户机回应server hello报文，建立如下的安全属性：协议版本、会话ID、密文族、压缩方法，同时生成并交换用于防止重放攻击的随机数。密文族参数包括密钥交换方法（Diffie-Hellman密钥交换算法、基于RSA的密钥交换和另一种实现在Fortezza chip上的密钥交换）、加密算法（DES、RC4、RC2、3DES等）、MAC算法（MD5或SHA-1）、加密类型（流或分组）等内容。

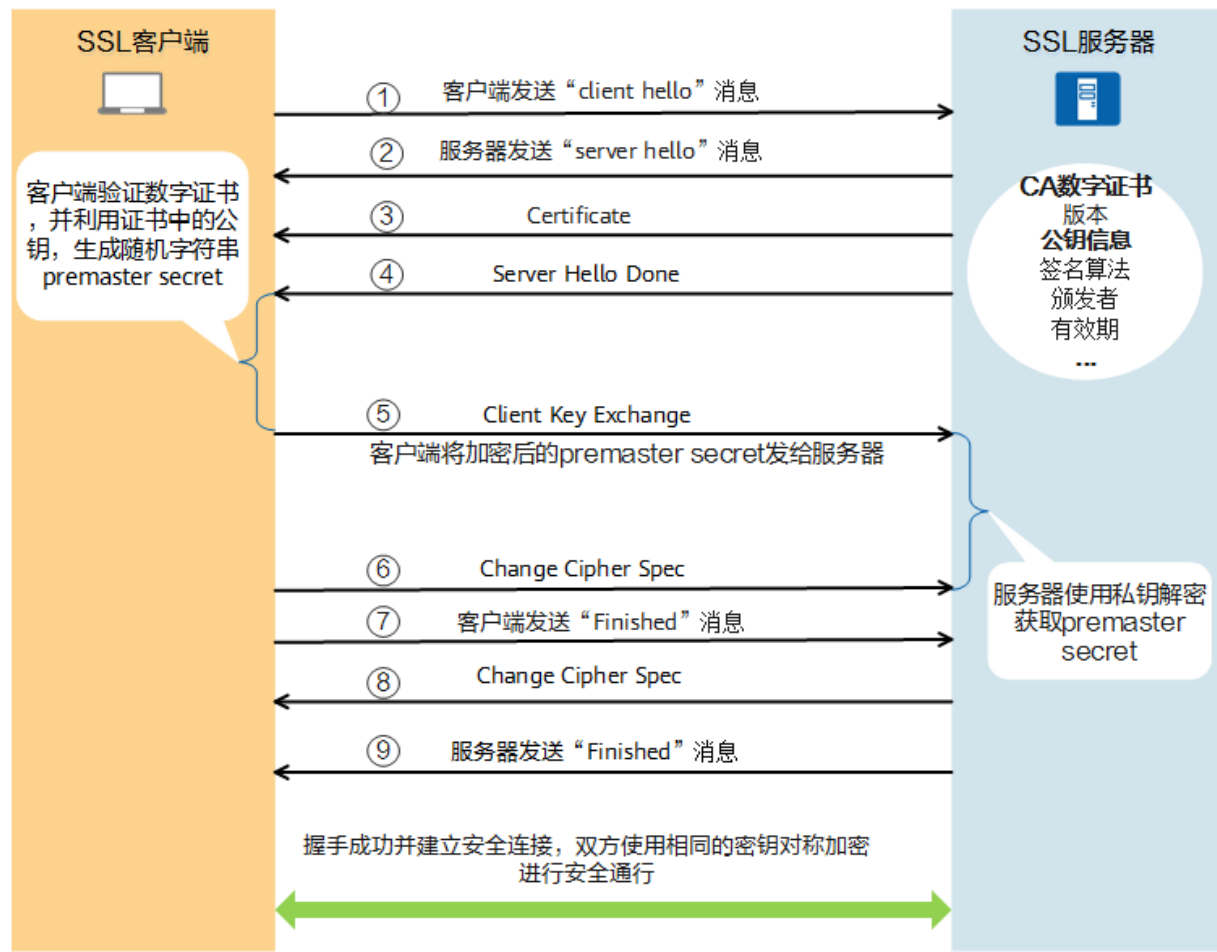


11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理——SSL握手协议

2. 认证服务器和密钥交换
：在hello报文之后，如果服务器需要被认证，服务器将发送其证书。然后，服务器可以向客户发送certificate request请求证书。服务器总是发送server hello done报文，指示服务器的hello阶段结束。

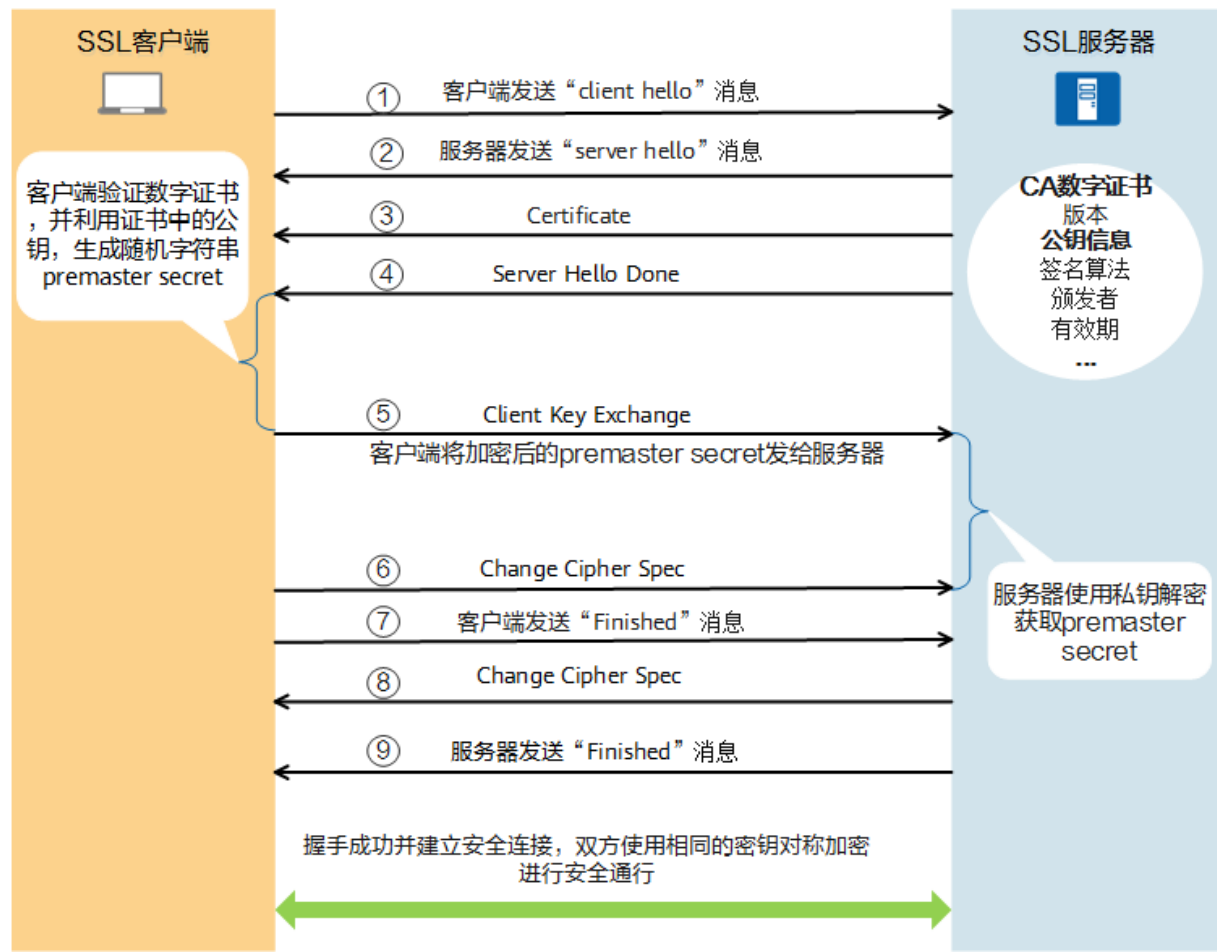


11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理——SSL握手协议

3. 认证客户和密钥交换：
客户一旦收到服务器的server hello done报文，客户将检查服务器证书的合法性（如果服务器要求），如果服务器向客户请求了证书，客户必须发送客户证书，然后发送client key_exchange报文，报文的内容依赖于client hello与server_hello定义的密钥交换的类型。最后，客户可能发送client verify报文来校验客户发送的证书，这个报文只能在具有签名作用的客户证书之后发送。



11.2 电子商务的安全技术和交易

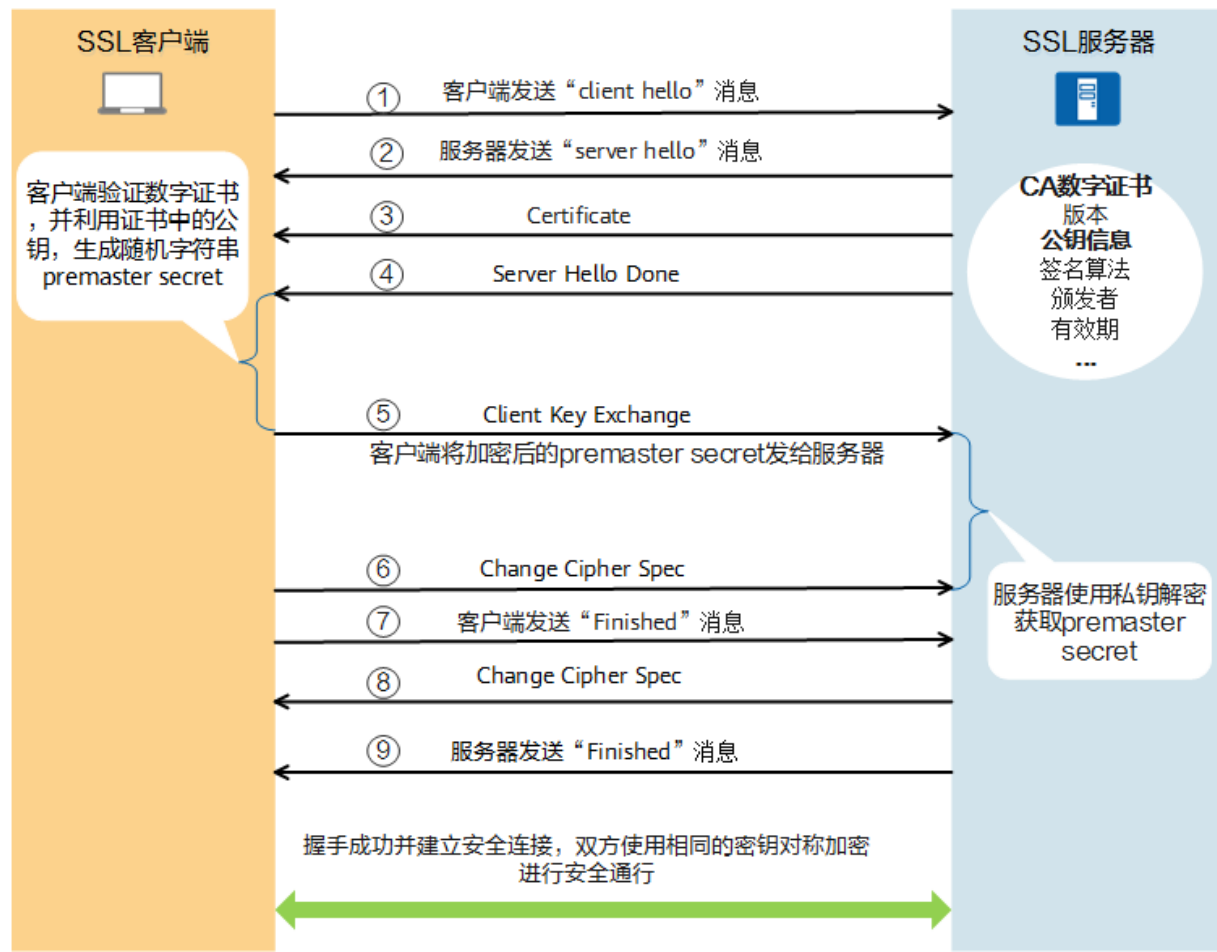
11.2.2 网上交易安全协议

3. SSL工作流程及原理——SSL握手协议

CipherSpec包括以下字段：加密算法，MAC算法，加密类型，可输出的，散列大小，密钥素材，IV大小

4. 结束：客户发送

change_cipher_spec报文并将挂起的CipherSpec复制到当前的CipherSpec。这个报文使用的是改变密码格式协议。然后，客户在新的算法、对称密钥和MAC秘密之下立即发送finished报文。finished报文验证密钥交换和鉴别过程是成功的。服务器对这两个报文响应，发送自己的change_cipher_spec报文、finished报文。握手结束，客户与服务器可以发送应用层数据了。





11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理——SSL握手协议

当客户从服务器端传送的证书中获得相关信息时，需要检查以下内容来完成对服务器的认证：时间是否在证书的合法期限内；签发证书的机关是否是客户端信任的；签发证书的公钥是否符合签发者的数字签名；证书中的服务器域名是否符合服务器自己真正的域名。服务器被验证成功后，客户继续进行握手过程。

同样的，服务器从客户传送的证书中获得相关信息认证客户的身份，需要检查：用户的公钥是否符合用户的数字签名；时间是否在证书的合法期限内；签发证书的机关是否是服务器信任的；用户的证书是否被列在服务器的LDAP (Lightweight Directory Access Protocol, 轻量级目录访问协议) 里用户的信息中；得到验证的用户是否仍然有权限访问请求服务器资源。



11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理——修改密码说明协议

表示密码策略的变化，在完成握手协议前客户端和服务端都要发送这一消息，以便通知对方其后的记录将用刚刚协商的密码规范及相关的密钥来保护。所有的更改密码规范消息都将产生一个意外消息警告。

11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理——报警协议

当握手过程或数据加密等操作出错误或发生异常情况时，向对方发出警告或终止当前连接。

报警协议的组成：第一个字节的值为warning或fatal，第二个字节是具体的告警消息。

waring：对发送方和接收方之间的连接没有影响，例如：错误证书、无证书、整数过期、证书未知、关闭通知，证书不支持、证书已撤销

fatal：会中断发送方和接收方之间的连接，例如：握手失败、解压失败、非法参数、错误记录MAC、意外消息



11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理——记录协议

SSL记录协议为SSL连接提供两种服务：机密性和报文完整性。

在SSL协议中，**所有的传输数据都被封装在记录中**。记录是由记录头和长度不为0的记录数据组成的。**所有的SSL通信都使用SSL记录层**，记录协议封装上层的握手协议、报警协议、更改密码说明协议和应用数据协议。SSL记录协议包括了记录头和记录数据格式的规定。

SSL记录协议位于SSL协议的底层，用于定义传输数据的格式，加密/解密、压缩/解压缩、MAC计算等操作。SSL记录协议将高层的协议数据分成较小的单元，并对它进行压缩、附加消息认证码MAC、加密、附加SSL记录头，然后通过低层的传输层协议发送，其过程如下图所示。

11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理——记录协议

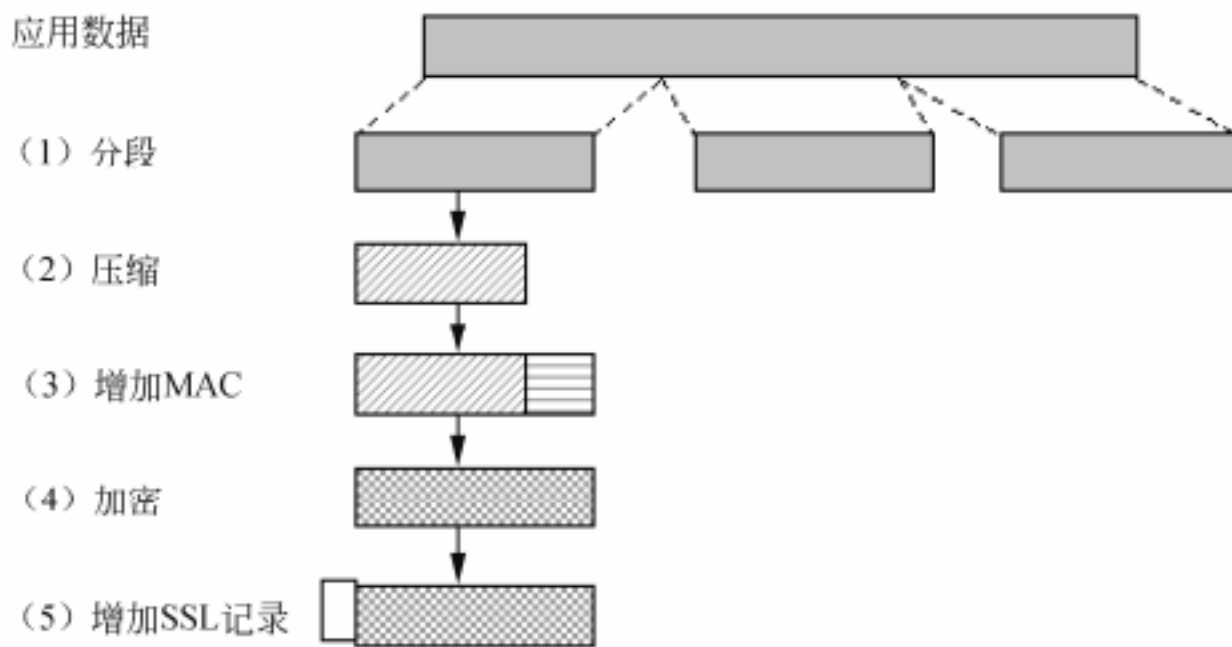


图 5-9 SSL 记录协议发送消息的过程

11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理——记录协议

1. **分段**：把上层传送来的数据信息块切分为小于或等于214字节的SSL明文记录。记录中包含类型、版本号、长度和数据字段。
2. **压缩**：使用当前会话状态中定义的压缩算法对被切分后的记录块进行压缩。压缩算法将SSL明文记录转化为SSL压缩记录。压缩是可选的，且必须是无损压缩，且对原文长度的增加不能超过1024字节。
3. **增加MAC**：在压缩数据上计算消息认证MAC。所有的记录均采用在当前的加密约定中定义的加密算法和报文验证MAC算法加以保护。当握手结束后，参与双方共享一个用于加密记录和计算消息认证码MAC的公开密钥。
4. **加密**：对压缩数据及MAC进行加密。加密和消息认证码(MAC)函数将一SSL压缩记录加密转换为一SSL密文记录。传输时将包含一序列号，这样即使包丢失、被改变或包被重复收到时也可以及时发现。
5. **增加SSL记录头**：SSL记录头由5个字节组成，第一个字节说明使用SSL记录协议的高层协议类型，如：20表示更改密码说明协议、21表示报警协议、22表示握手协议、23表示应用数据协议；第二个字节表示主要版本号，如：对于SSLv3.0,值为3；第三个字节表示次要版本号，如：对于SSLv3.0,值为0；第四、第五个字节表示明文数据（如果选用压缩则是压缩数据)的长度。

内容类型	主要版本	次要版本	压缩长度
明文（压缩可选）			
MAC（0, 16 或 20 位）			

图 5-10 SSL 记录协议字段

11.2 电子商务的安全技术和交易

11.2.2 网上交易安全协议

3. SSL工作流程及原理

在完成以上握手过程后，**SSL** 客户机与**SSL** 服务器之间传送的信息都是加密的，收信方解密而无法了解信息的内容。在电子商务交易过程中，由于有银行参与交易过程，客户购买的信息首先发往商家，商家再将这些信息转发给银行，银行验证客户信息的合法性后，通知商家付款成功，商家再通知客户购买成功，然后将商品送到客户手中。

SSL 安全协议缺点，主要包括：不能自动更新证书；认证机构编码困难；浏览器的口令具有随意性；不能自动检测证书撤销表；用户的密钥信息在服务器上是以明文方式存储的。另外，**SSL** 虽然提供了信息传递过程中的安全性保障，但是信用卡的相关数据应该是银行才能看到，然而这些数据到了商家端都被解密，客户的数据都完全暴露在商家的面前。**SSL** 安全协议虽然存在弱点，但由于它操作容易，成本低，而且又在不断改进，所以在欧美等地的商业网站的应用是非常广泛。



11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

网络安全电子交易 (Secure Electronic Transaction, **SET**) 是一个通过Internet等开放网络进行安全交易的**技术标准**, 1996年由两大信用卡国际组织VISA和MasterCard共同发起制定并联合推出。由于得到了IBM、HP、Microsoft 和 RSA 等大公司的协作与支持, 已成为事实上的工业标准并得到了认可。SET 协议**围绕客户、商家等交易各方相互之间身份的确认, 采用了电子证书等技术, 以保障电子交易的安全**。SET 向基于信用卡进行电子化交易的应用提供了实现安全措施的规则。

SET 主要由**3个文件组成**, 分别是 SET 业务描述、SET 程序员指南和 SET 协议描述。

SET **规范涉及的范围**有: 加密算法的应用(如 RSA 和DES)、证书信息和对象格式、购买信息和对象格式、确认信息和对象格式; 划账信息和对象格式、对话实体之间消息的传输协议。



11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

1. SET的主要目标

- 1) **信息传输的安全性**。信息在网络上安全传输，保证信息传输安全送达。
- 2) **信息的相互隔离**。订单信息和个人账号信息的隔离，当包含持卡人账号信息的订单送到商家时，商家只能看到订货信息，而看不到持卡人的账号信息。
- 3) **需要多方认证**：①要对消费者的信用卡认证；②要对网上商店进行认证；③消费者、商店与银行之间的认证。
- 4) **效仿EDI 贸易形式**，要求软件遵循相同协议和报文格式，使不同厂家开发的软件具有兼容和互操作功能，并且可以运行在不同的硬件和操作系统平台上。
- 5) **交易的实时性**。所有的支付过程都是在线并实时完成的。



11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

2. SET的交易成员

1) **持卡人**：持卡消费者，包括个人消费者和团体消费者，按照网上商店的表单格式填写，通过由发卡银行发行的信用卡进行付费。

2) **网上商家**：在网上的符合 SET 规格的电子商店，提供商品或服务，它必须是具备相应电子货币使用的条件、从事商业交易的公司或组织。

3) **收单银行**：通过支付网关处理持卡人和商店之间的交易付款问题事务。接收来自商店端送来的交易付款数据，向发卡银行验证无误后，取得信用卡付款授权，以供商店清算。



11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

2. SET的交易成员

4) **支付网关**：这是由支付者或指定的第三方完成的功能。为了实现授权或支付功能，支付网关将 SET 和现有的银行卡支付的网络系统作为接口。在互联网上，商家与支付网关交换 SET 信息，而支付网关与支付者的财务处理系统具有一定的直接连接或网络连接。

5) **发卡银行**：电子货币发行公司或兼有电子货币发行的银行：发行信用卡给持卡人的银行机构。在交易过程开始前，发卡银行负责查验持卡人的数据，如果查验有效，整个交易才能成立。在交易过程中负责处理电子货币的审核和支付工作。



11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

2. SET的交易成员

6) 认证中心CA: 可信赖、公正的组织。接受持卡人、商店、银行以及支付网关的数字认证申请书, 并管理数字证书的相关事宜, 如制定核发准则, 发行和注销数字证书等。负责对交易双方的身份确认, 对厂商的信誉和消费者的支付手段和支付能力进行认证。

SET支付系统中的交易成员如图11-3所示。

11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

2. SET支付系统中的交易成员

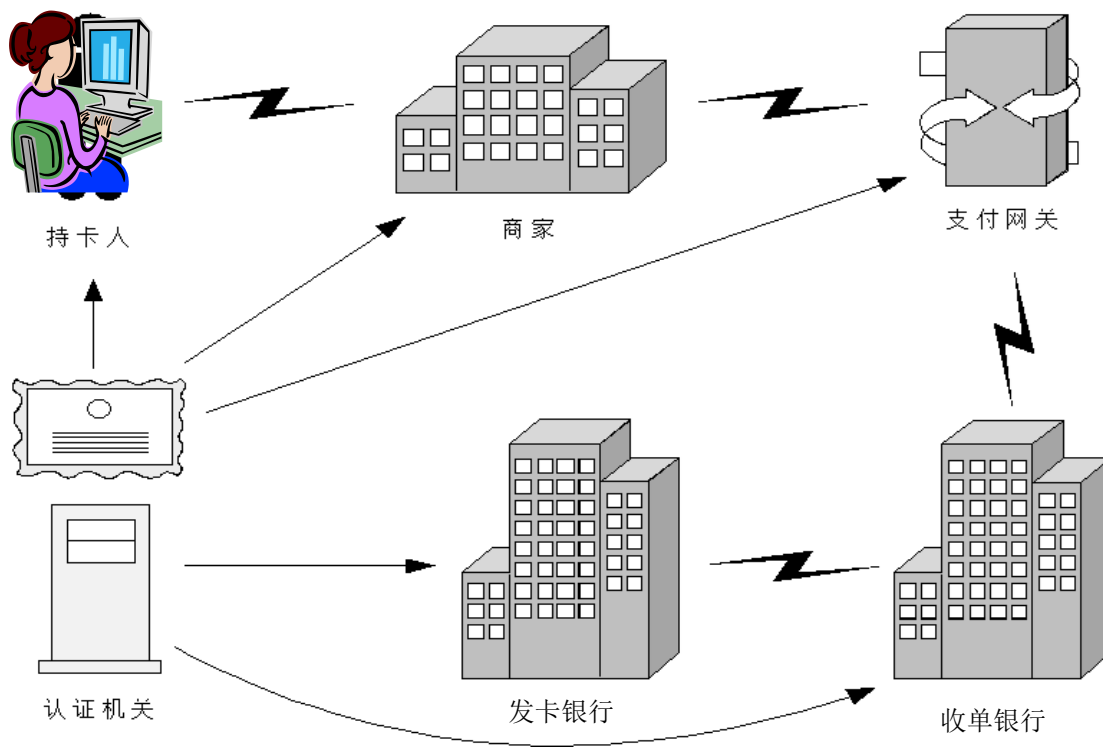


图11-3 SET支付系统中的交易成员

11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

3. SET的技术范围

SET 的技术范围包括以下几方面：加密算法、证书信息和对象格式、购买信息和对象格式、认可信息和对象格式、划账信息和对象格式、对话实体之间消息的传输协议。



11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

4. SET系统的组成

SET系统的操作通过4个软件完成，包括电子钱包、商店服务器、支付网关和认证中心软件，这4个软件分别存储在持卡人、网上商店、银行以及认证中心的服务器中，相互运作完成整个SET交易服务。



11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

4. SET系统的组成

安全电子交易SET系统的一般模型如图11-4所示所示。

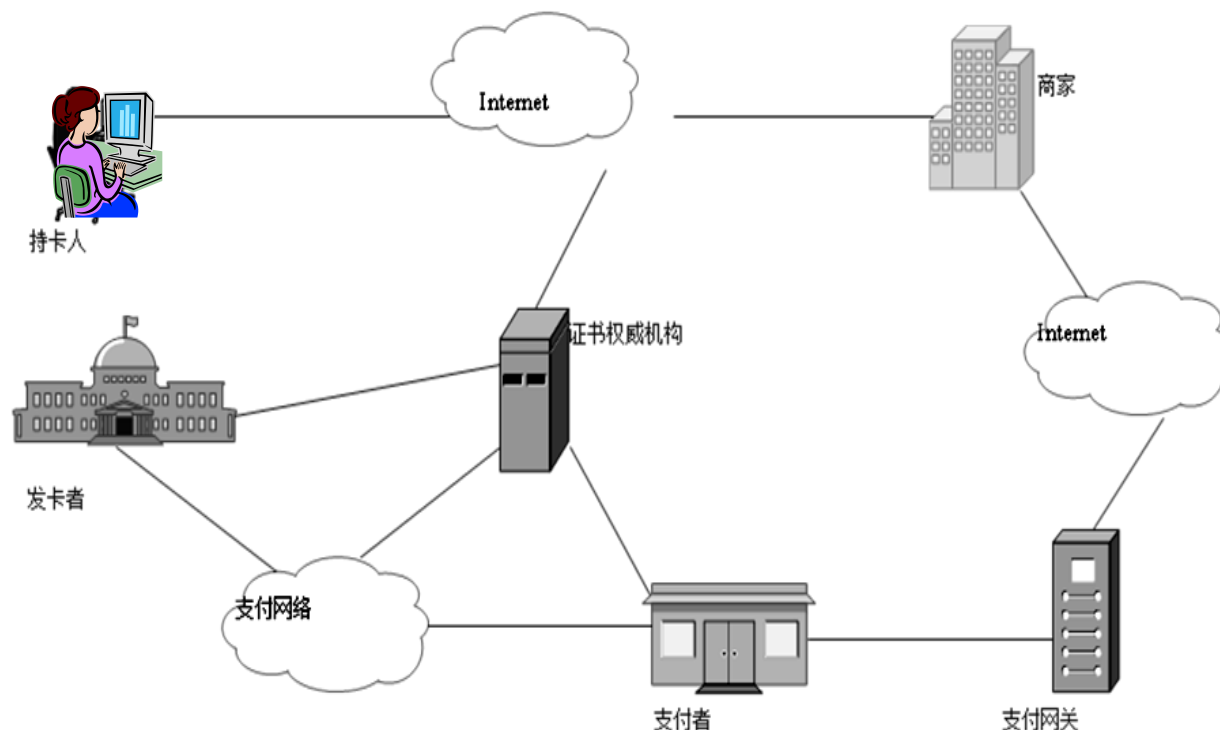


图11-4 安全电子商务组成

11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

4. SET系统的组成

- 1) **持卡人**。持卡人是发行者发行的支付卡(例如MasterCard 和 VISA)的授权持有者。
- 2) **商家**。商家是有货物或服务出售给持卡人的个人或组织。通常, 这些货物或服务可以通过 Web 站点或电子邮件提供。
- 3) **支付者**。建立商家的账户并实现支付卡授权和支付的金融组织。支付者为商家验证给定的信用卡账户是可用的;支付者也对商家账户提供支付的电子转账。
- 4) **支付网关**。支付网关是由支付者或指定的第三方完成的功能。为了实现授权或支付功能, 可以将支付网关作为 SET 和现有银行卡支付的网络系统的接口。在 Internet 上, 商家与支付网关交换 SET 信息, 而支付网关与支付者的财务处理系统具有一定的直接连接或网络连接。
- 5) **证书权威机构**。证书权威机构是为持卡人、商家和支付网关发行 X.509v3 公共密码证书的可信实体。



11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

5. SET的认证过程

基于SET 协议电子商务系统的业务过程可分为注册登记、申请数字证书、动态认证和商业机构的处理。具体主要业务认证过程有4 个步骤：

11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

5. SET系统的认证过程

(1) 注册登记

当一个机构希望加入到基于SET 协议的安全电子商务系统中时，必须先上网申请注册登记，申请数字证书。每个在认证中心进行注册登记的用户都会得到**非对称密钥密码体制**的一对密钥：一个公钥和一个私钥。公钥用于提供对方解密和加密回馈的信息内容，私钥用于解密对方的信息和加密发出的信息。



11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

5. SET系统的认证过程

密钥在加解密处理过程的作用包括：

- ①对持卡人购买者的作用：用私钥解密回函；用商家公钥填发订单；用银行公钥填发付款单和数字签名等。
- ②对银行的作用：用私钥解密付款及金融数据；用商家公钥加密购买者付款通知。
- ③对商家供应商的作用：用私钥解密订单和付款通知；用购买者公钥发出付款通知和代理银行公钥。



11.2 电子商务的安全技术和交易

(2) 申请数字证书

SET 数字证书申请工作的具体步骤如图11-5 所示。

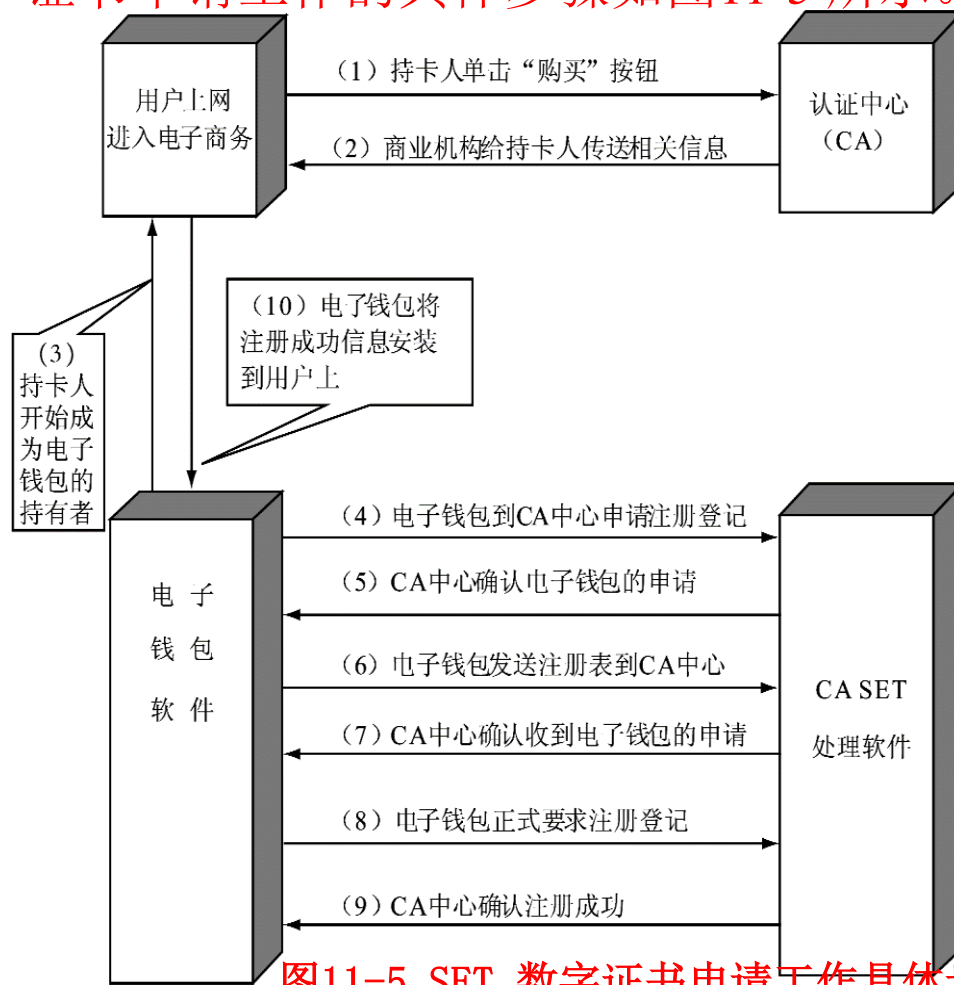


图11-5 SET 数字证书申请工作具体步骤

11.2 电子商务的安全技术和交易

(3) 动态认证

注册成功后，便可以在网络上进行电子商务活动。在从事电子商务交易时，SET系统的动态认证工作过程如图11-6 所示。

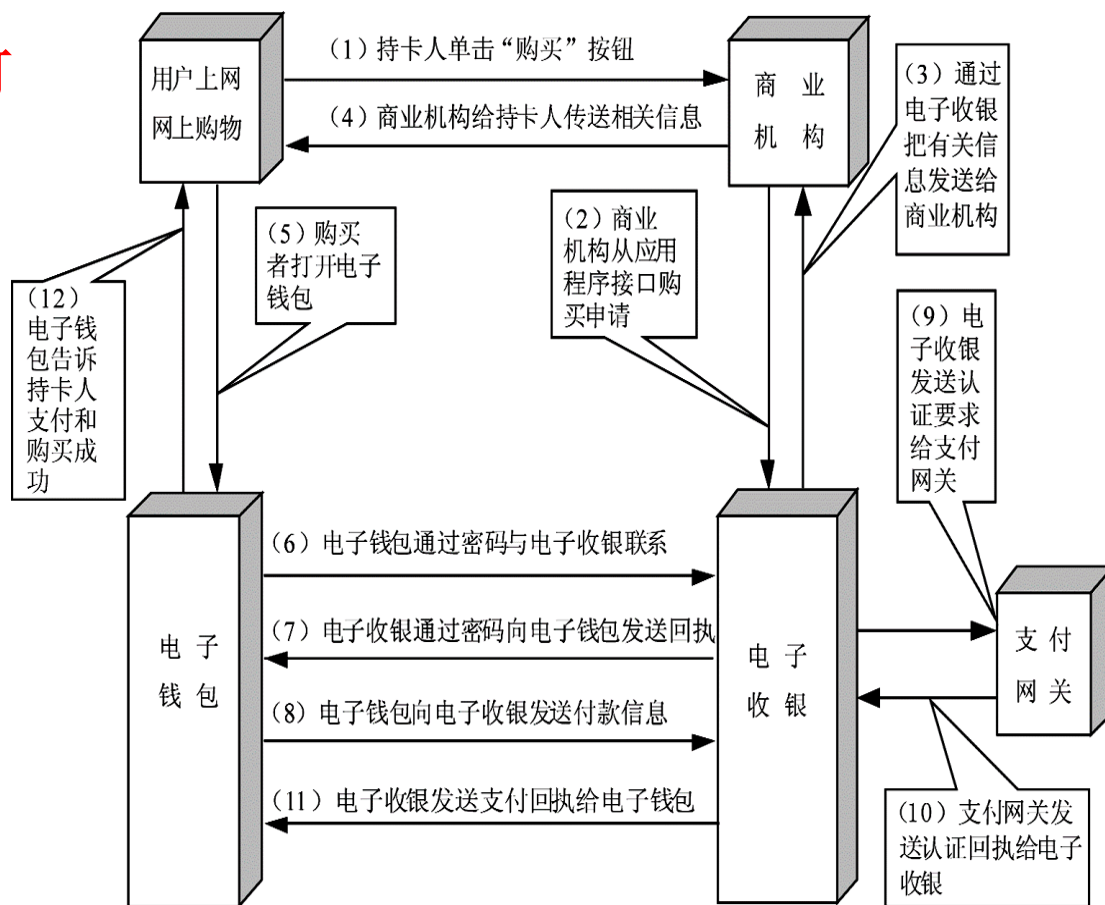


图11-6 SET 系统的动态认证工作步骤

11.2 电子商务的安全技术和交易

(4) 商业机构处理

商业机构处理流程商业机构的处理工作步骤如图11-7 所示。

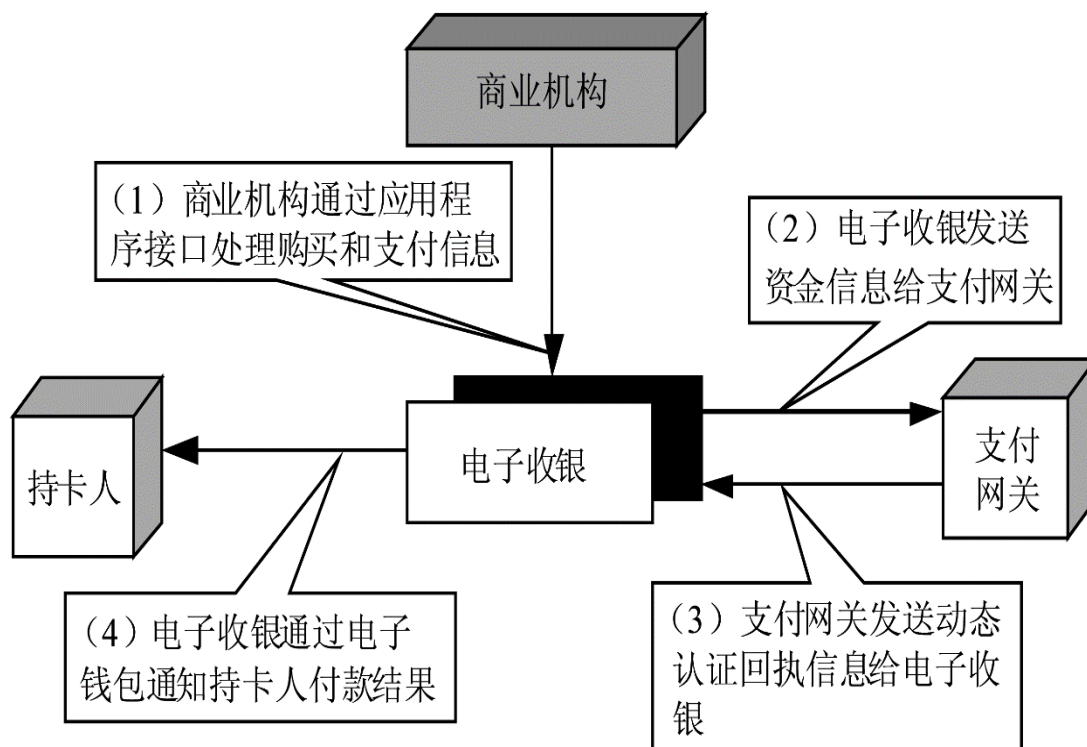
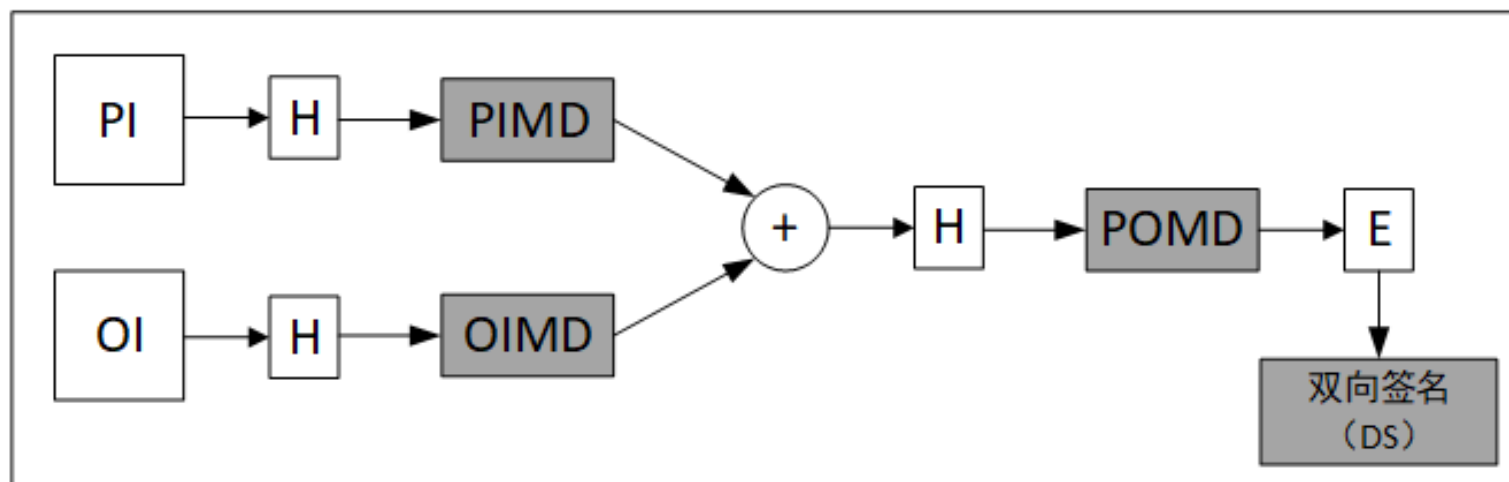


图11-7 SET 系统的商业机构工作步骤

11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

5. SET系统的认证过程

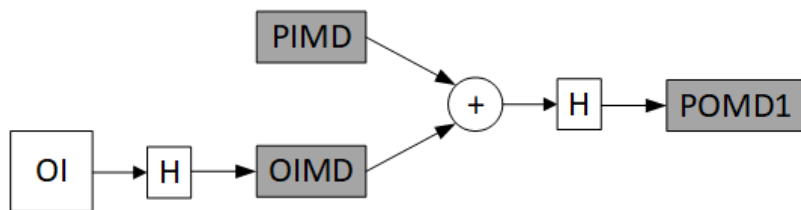


11.2 电子商务的安全技术和交易

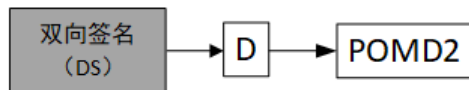
11.2.3 网络安全电子交易

5. SET系统的认证过程

第一步：商家计算OIMD，用它从持卡人那里收到的PIMD生成POMD（设为POMD1）



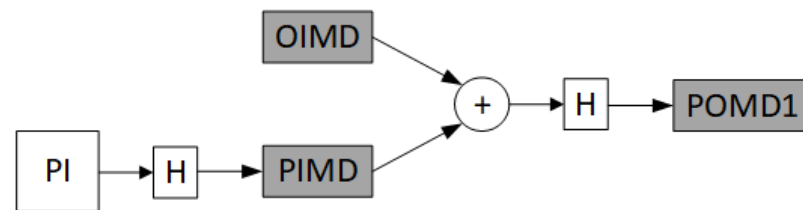
第二步：商家从持卡人那里收到的DS解密，以计算POMD（设为POMD2）



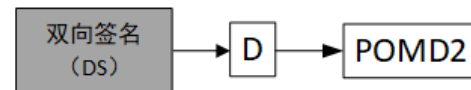
第三步：商家比较POMD1与POMD2，如果相等，则信任该消息，即确认他是来自持卡人的

POMD1 = POMD2 ? 如果是，接收，否则拒绝该消息

第一步：付款网关计算PIMD，用它从持卡人那里收到的OIMD生成POMD（设为POMD1）



第二步：付款网关从持卡人那里收到的DS解密，以计算POMD（设为POMD2）



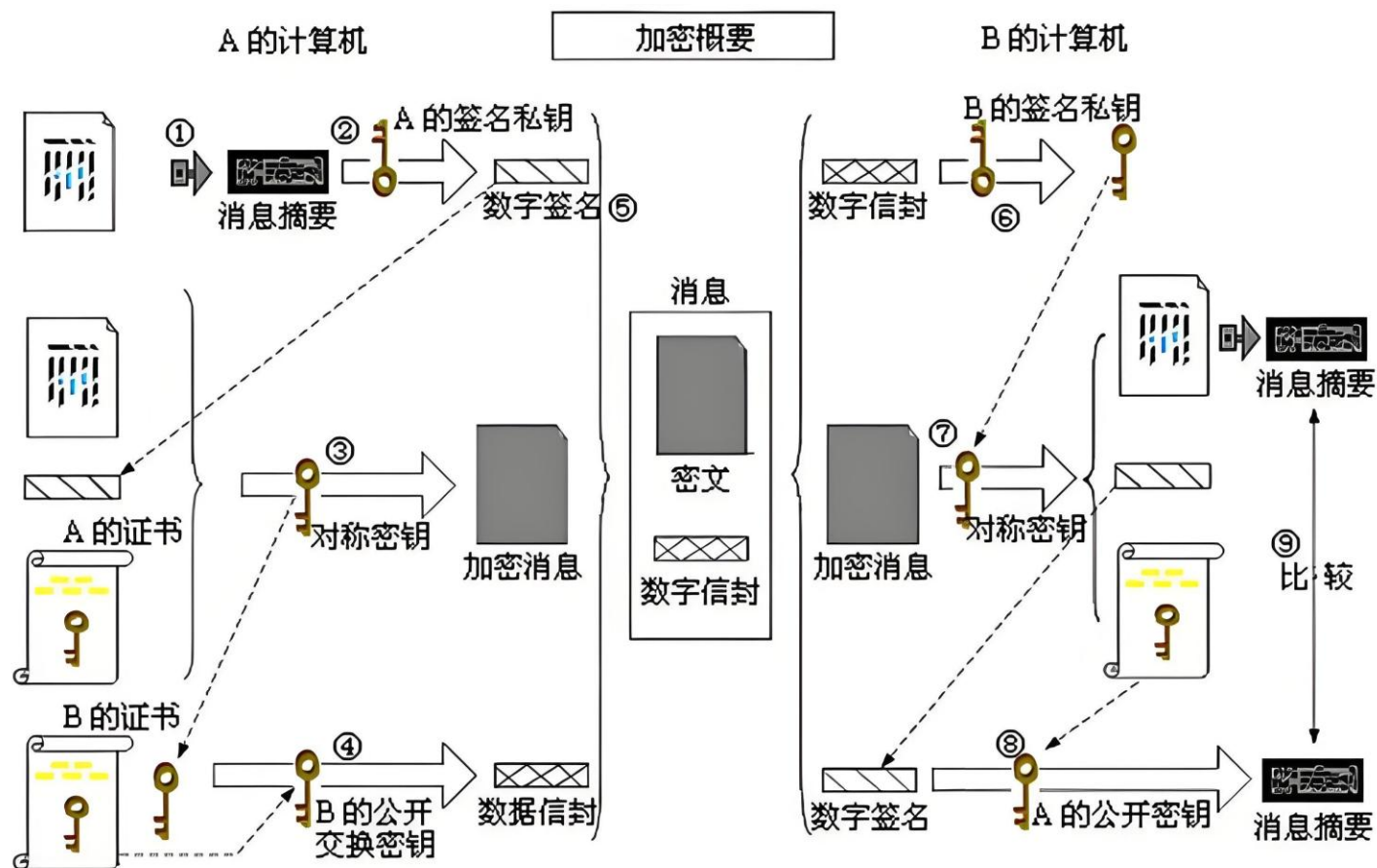
第三步：付款网关比较POMD1与POMD2，如果相等，则信任该消息，即确认他是来自持卡人的

POMD1 = POMD2 ? 如果是，接收，否则拒绝该消息

11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

5. SET系统的认证过程



11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

5. SET系统的认证过程

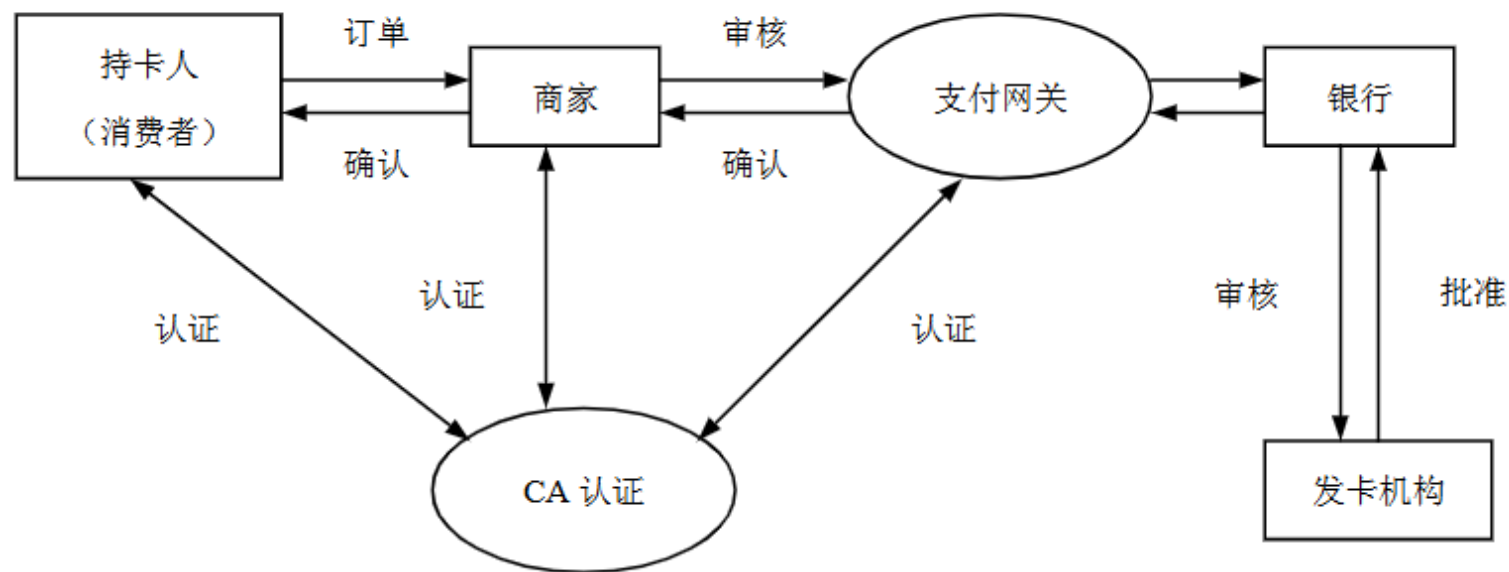


图 5-6 SET 协议的处理流程

11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

5. SET系统的认证过程

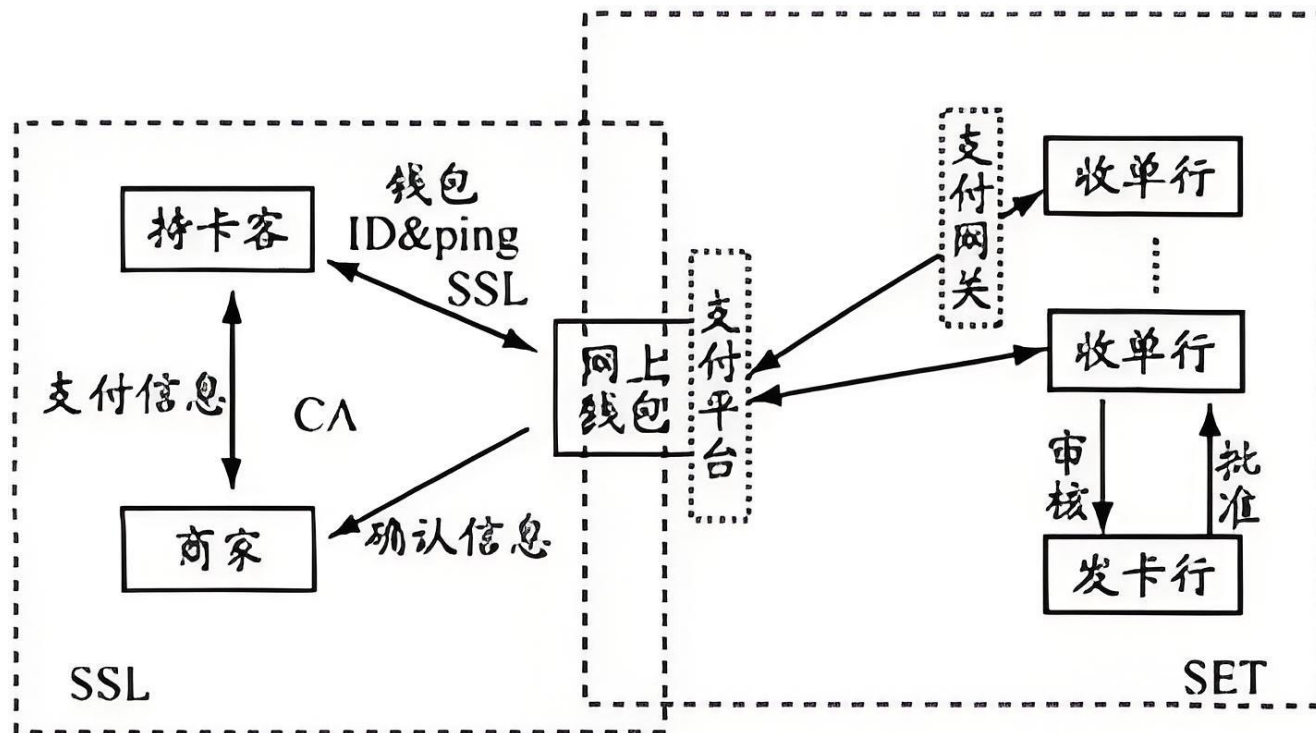


图 4 网上钱包支付流程

11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

6. SET协议的安全技术

SET 在不断地完善和发展变化。SET 有一个**开放工具SET Toolkit**，任何电子商务系统都可以利用它处理操作过程中的安全和保密问题。其中支付和认证是SET Toolkit 向系统开发者提供的**两大主要功能**。





11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

6. SET协议的安全技术

主要安全保障有以下3个方面：

- 1) 用非对称密钥密码体制加密文件；
- 2) 增加密钥的公钥和私钥的字长；
- 3) 采用联机动态的授权和认证检查，以确保交易过程的安全可靠。

安全保障措施的技术基础有4个：

- 1) 利用加密方式确保信息机密性。
- 2) 以数字化签名确保数据的完整性。
- 3) 使用数字化签名和商家认证确保交易各方身份的真实性。
- 4) 通过特殊的协议和消息形式确保动态交互式系统可操作性。

☺讨论思考：

- 1) 电子商务安全技术具体有哪些？
- 2) 怎样理解网上交易安全协议的重要性？
- 3) 什么是网络安全电子交易？



11.2 电子商务的安全技术和交易

11.2.3 网络安全电子交易

SSL v. s. SET

项目	SSL 协议	SET 协议
工作层次	传输层与应用层之间	应用层
是否透明	透明	不透明
过程	简单	复杂
效率	高	低
安全性	商家掌握消费者	消费者对商家保密
认证机制	双方认证	多方认证
是否专为 EC 设计	否	是

11.3 构建基于SSL的Web安全站点

构建基于SSL的Web安全站点包括：基于Web信息安全通道的构建，以及数字证书服务的安装与管理有关的实际应用操作。



11.3 构建基于SSL的Web安全站点

11.3.1 基于Web安全通道的构建

安全套接层协议SSL是一种在两台主机之间提供安全通道的协议，具有保护传输数据以及识别通讯机器的功能。在协议栈中，SSL协议位于应用层下TCP层之上，并且整个SSL协议API和微软提供的套接字层的API极为相似。因为很多协议都在TCP上运行，而SSL连接与TCP连接非常相似，所以通过在SSL上附加现有协议来保证其安全是一项非常好的设计方案。

目前，SSL之上的协议有http、nntp、smtp、telnet和FTP，另外，国内开始用SSL保护专有协议。最常用的是**Openssl开发工具包**，用户可以调用其中API实现数据传输的加密解密以及身份识别。Microsoft的IIS服务器也提供了对SSL协议的支持。

11.3 构建基于SSL的Web安全站点

11.3.1 基于WEB安全通道的构建

1. 配置DNS、Active Directory及CA服务

建立一个**CA认证服务器**需要Windows Server上有DNS和Active Directory服务，并需要进行配置。用户只要按照“管理工具”中的“配置服务器”向导操作即可。另外，为了操作方便，CA认证中心的颁发策略要设置成“**始终颁发**”。

2. 服务器端证书的获取与安装

- 1) 获取WEB站点数字证书。
- 2) 安装WEB站点数字证书。
- 3) 设置“安全通信”属性。



11.3 构建基于SSL的Web安全站点

11.3.1 基于WEB安全通道的构建

3. 客户端证书的获取与安装

客户如果想通过信息安全通道访问需要安全认证的网站，必须具有此网站信任的CA机构颁发证书以及CA认证机构的证书链。

申请客户端证书步骤：

- 1) 申请客户端证书。
- 2) 安装证书链。



4. 通过安全通道访问需要认证的WEB网站

客户安装证书和证书链后，就可以访问需要客户端认证的网站了。在浏览器中输入网址**https://WEB服务器地址: SSL端口 /index.htm**，其中**https**表示浏览器要通过安全信息通道（即SSL, 安全套接层）访问web站点，并且如果服务器的SSL端口不是默认的443端口，那么在访问的时候要指明SSL端口。在连接刚建立时，浏览器会弹出一个安全警报对话框，是浏览器在建立SSL通道之前对服务器端证书进行分析，用户单击“确定”后，浏览器把客户端已有的用户证书全部显示，供用户选择，选择正确的证书后单击“确定”按钮。



11.3 构建基于SSL的Web安全站点

11.3.1 基于WEB安全通道的构建

5. 通过安全通道访问Internet

在Internet上的数据信息基本是明文传送，各种敏感信息遇到如嗅探等专业软件就很容易泄密，网络用户没有办法保护各自的合法权益，网络无法充分发挥其方便快捷安全高效的效能，会严重影响我国电子商务和电子政务的建设与发展，阻碍B/S系统软件的推广。

通过研究国外的各种网络安全解决方案，认为采用最新的SSL（安全套接层）技术，构建安全信息通道是一种在安全性，稳定性，可靠性方面都很优秀的解决方案。



11.3 构建基于SSL的Web安全站点

11.3.1 基于WEB安全通道的构建

5. 通过安全通道访问Internet

以上是在一种较简单的网络环境中实现的基于 SSL 的安全信息通道的构建，IIS 这种Web 服务器只能实现 128 位的加密，很难满足更高安全性用户的需求。用户可以根据各自的需要来选择 Web 服务器软件和 CA 认证软件，最实用的是 OPENSSL 自带的安全认证组件，可实现更高位数的加密，以满足用户各种安全级别的需求。

11.3 构建基于SSL的Web安全站点

11.3.1 基于WEB安全通道的构建

案例11—3

零售和高科技行业是最热门的网络攻击目标：在2022年的前六个月，针对在线应用程序的恶意交易有所增加，主要是可预测的资源定位和注入攻击。与2021年前六个月相比，恶意Web应用程序交易数量增长了38%，超过了2020年记录的恶意交易总数。可预测的资源定位攻击占有所有攻击的48%，其次是代码注入（17%）和SQL注入（10%）。受攻击最多的行业是零售和批发贸易（27%）和高科技（26%）。运营商和SaaS提供商排名第三和第四，分别承受了14%和7%的攻击。

11.3 构建基于SSL的Web安全站点

11.3.1 基于WEB安全通道的构建

5. 通过安全通道访问Internet

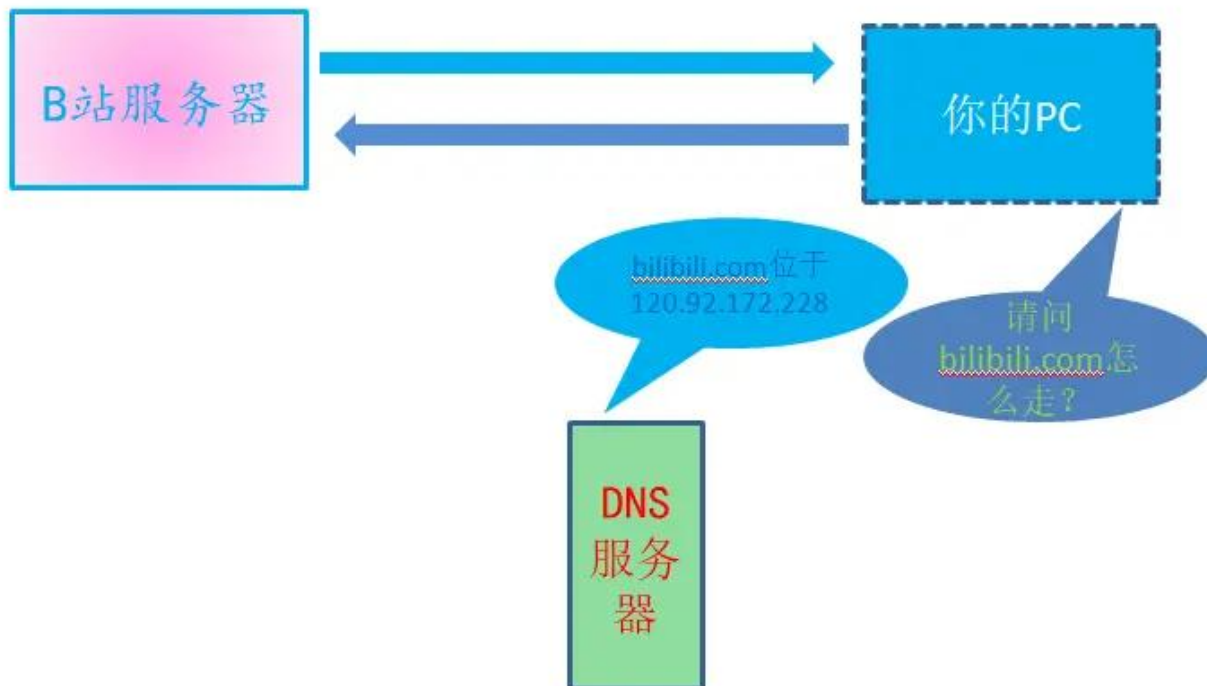
需要注意：基于安全通道的通信并不能保证传输过程中所有的信息都加密。例如通信目的地的IP地址是非加密，其主要原因在于DNS是非加密的。非加密的DNS会导致如下问题：

- 1) 网络中间路由等都可嗅探通信内容并可能篡改, 造成钓鱼诈骗和网络攻击;
- 2) 解析服务器不可信, 污染DNS大量存在, 造成用户隐私大面积泄露, 各种定向广告轰炸随之而来;
- 3) 通过解析容易被防火墙识别, 从而被对方加以各种限流和屏蔽。

11.3 构建基于SSL的Web安全站点

11.3.1 基于WEB安全通道的构建

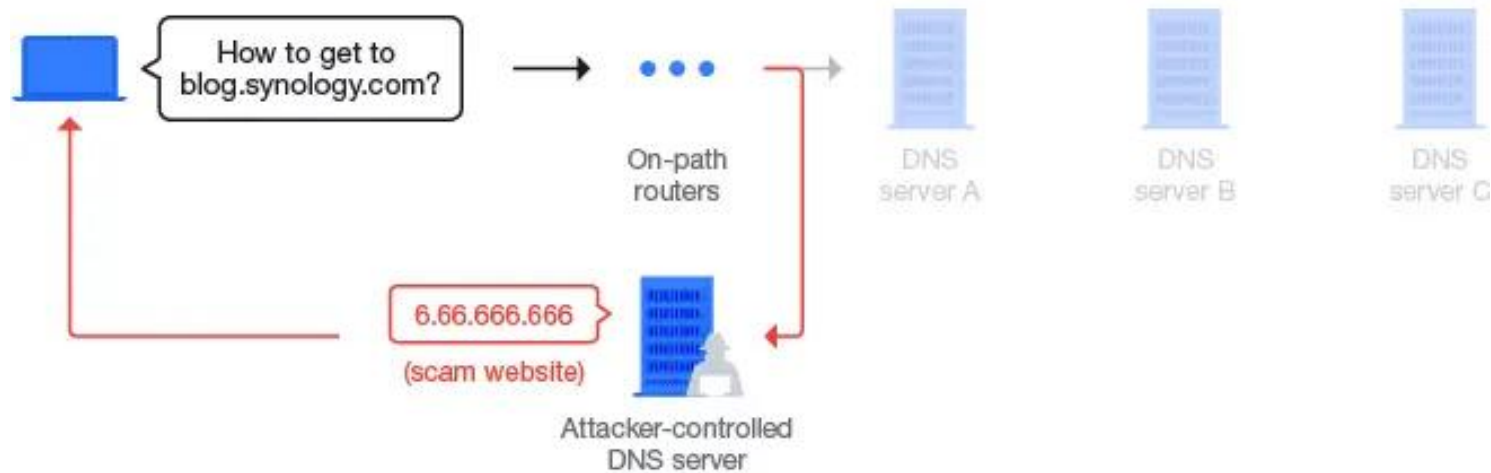
DoH



11.3 构建基于SSL的Web安全站点

11.3.1 基于WEB安全通道的构建

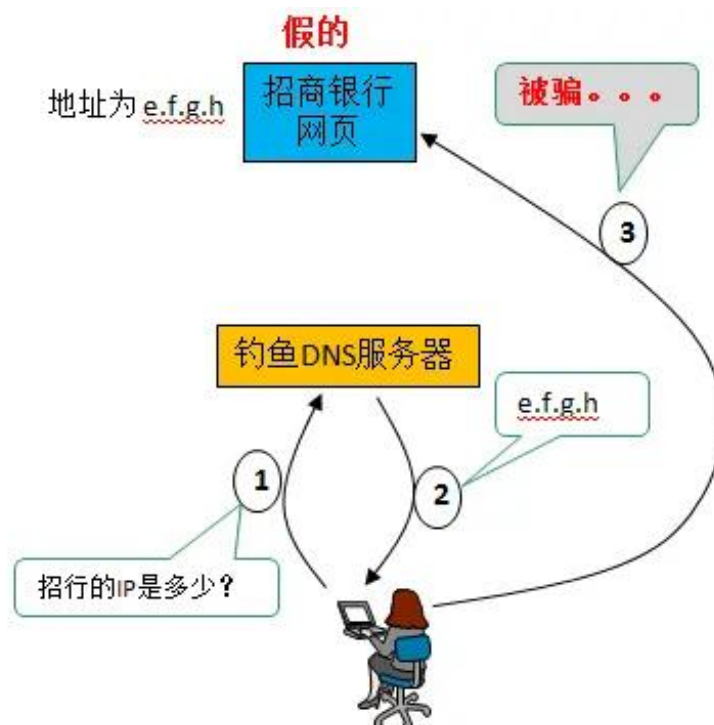
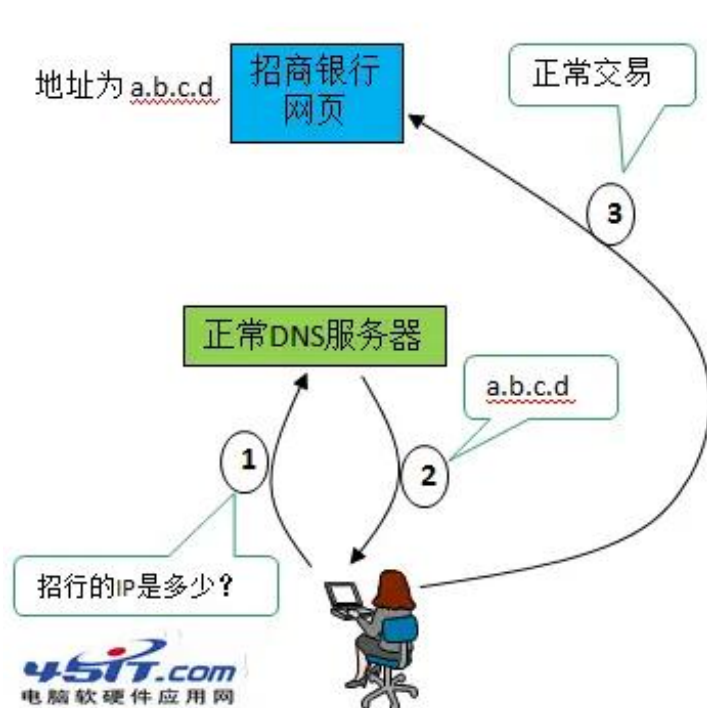
DoH



11.3 构建基于SSL的Web安全站点

11.3.1 基于WEB安全通道的构建

DoH

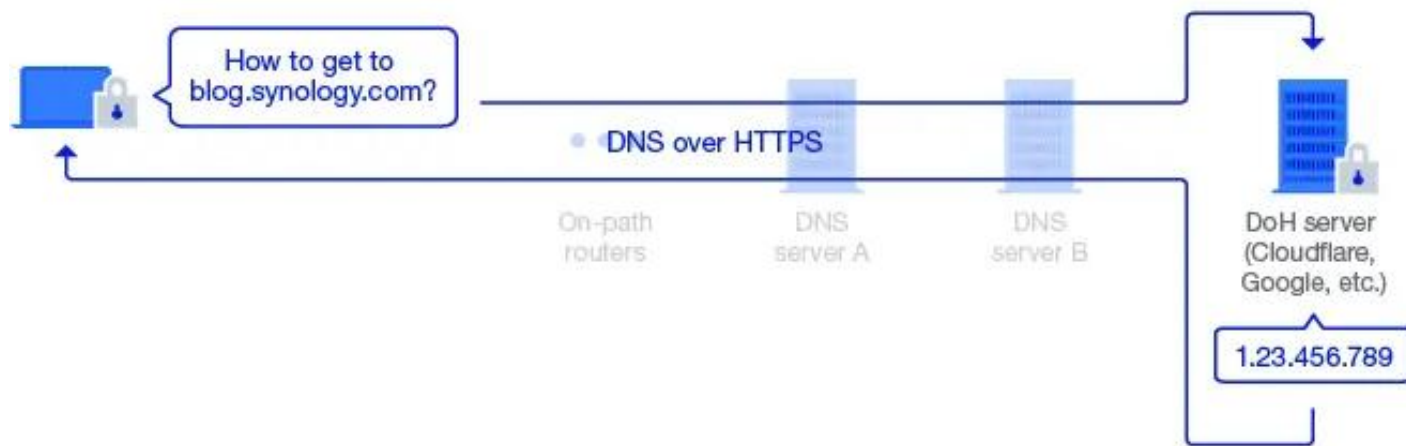


11.3 构建基于SSL的Web安全站点

11.3.1 基于WEB安全通道的构建

DoH

顾名思义，DoH拥有了Https的特性。DNS over Https是一个进行安全化域名解析的方案，当前尚处于实验性阶段。其意义在于以加密的Https协议进行DNS解析请求，避免原始DNS协议中用户的DNS解析请求被窃听或者修改的问题（例如中间人攻击）来达到保护用户隐私的目的。Google及Mozilla基金会正在测试这一协议，作为其提高网络安全性努力的一部分。DoH不仅可以避开DNS劫持，还能避开DNS域名污染。



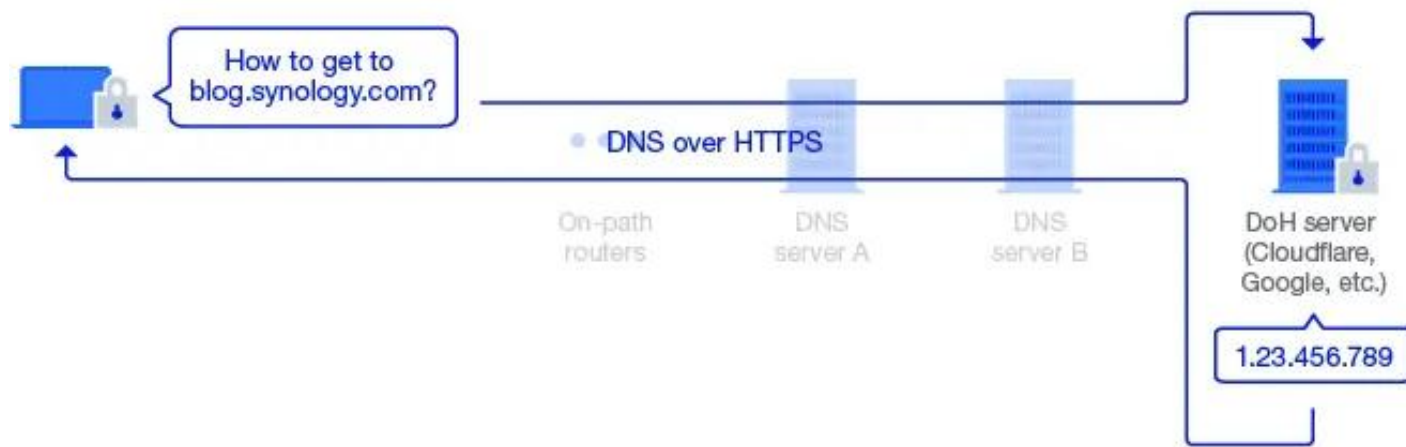
11.3 构建基于SSL的Web安全站点

11.3.1 基于WEB安全通道的构建

DoH

解决这个问题常用的是DNS over https (DoH)，主要特点如下：

- 1) DNS的解析请求和解析结果经由中间路由时都不可被解密，实现了用户端和解析服务器之间端到端的加密，隐私不在中途泄露；
- 2) 双向请求和结果数据因为加密算法的存在保证不可被篡改，阻止了借用DNS的钓鱼攻击和拒绝服务攻击；
- 3) 无法通过判定用户访问域名的行为来触发防火墙规则，有效保障上网体验和联通性。



11.3 构建基于SSL的Web安全站点

11.3.2 证书服务的安装与管理

构建基于 SSL 的 Web 站点需要下载数字证书并进行**数字证书安装与管理**，只有使用具有 SSL 及 SET 的网站，才能真正实现网上安全交易。SSL 是对会话的保护，SSL 最为普遍的应用是实现浏览器和 WWW 服务器之间的安全 HTTP 通信。SSL 所提供的安全业务有实体认证、完整性和保密性，还可通过**数字签名提供不可否认性**。

案例11-4

中华人民共和国电子签名法：为保证电子商务的安全，国家**2004年8月28日**颁布了《中华人民共和国电子签名法》，大力推进电子签名、电子认证和数字证书等安全技术手段的广泛应用。目前版本是**2019年4月23日**第二次修正。

11.3 构建基于SSL的Web安全站点

11.3.2 证书服务的安装与管理

数字证书服务的安装与管理可以通过以下方式进行操作。

1) 打开Windows控制面板, 单击“添加/删除程序”按钮, 再单击“添加/删除Windows 组件”按钮, 弹出“Windows 组件向导”对话框, 选中“证书服务”复选框。



图11-8 “Windows 组件向导”对话框

11.3 构建基于SSL的Web安全站点

11.3.2 证书服务的安装与管理

在Windows Server控制面板，单击“更改安全设置”，出现“Internet属性对话框”（或在IE浏览器中选择“工具”中的“Internet选项”），可以通过选择“内容”选项卡中“证书”按钮，进行数字证书对话框，如图11-9所示对话框。

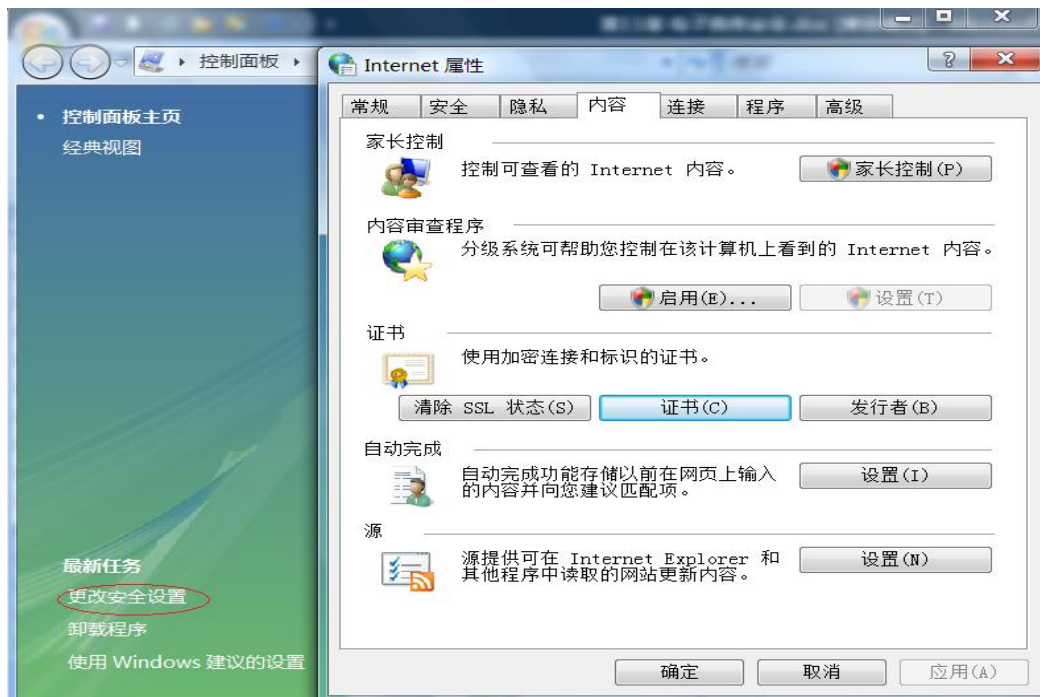


图11-9 Windows控制面板及“Internet属性”对话框

11.3 构建基于SSL的Web安全站点

11.3.2 证书服务的安装与管理

单击“内容”选项卡中“证书”按钮，出现“证书”对话框。单击“高级选项”可以出现如图11-10所示的“高级选项”对话框。

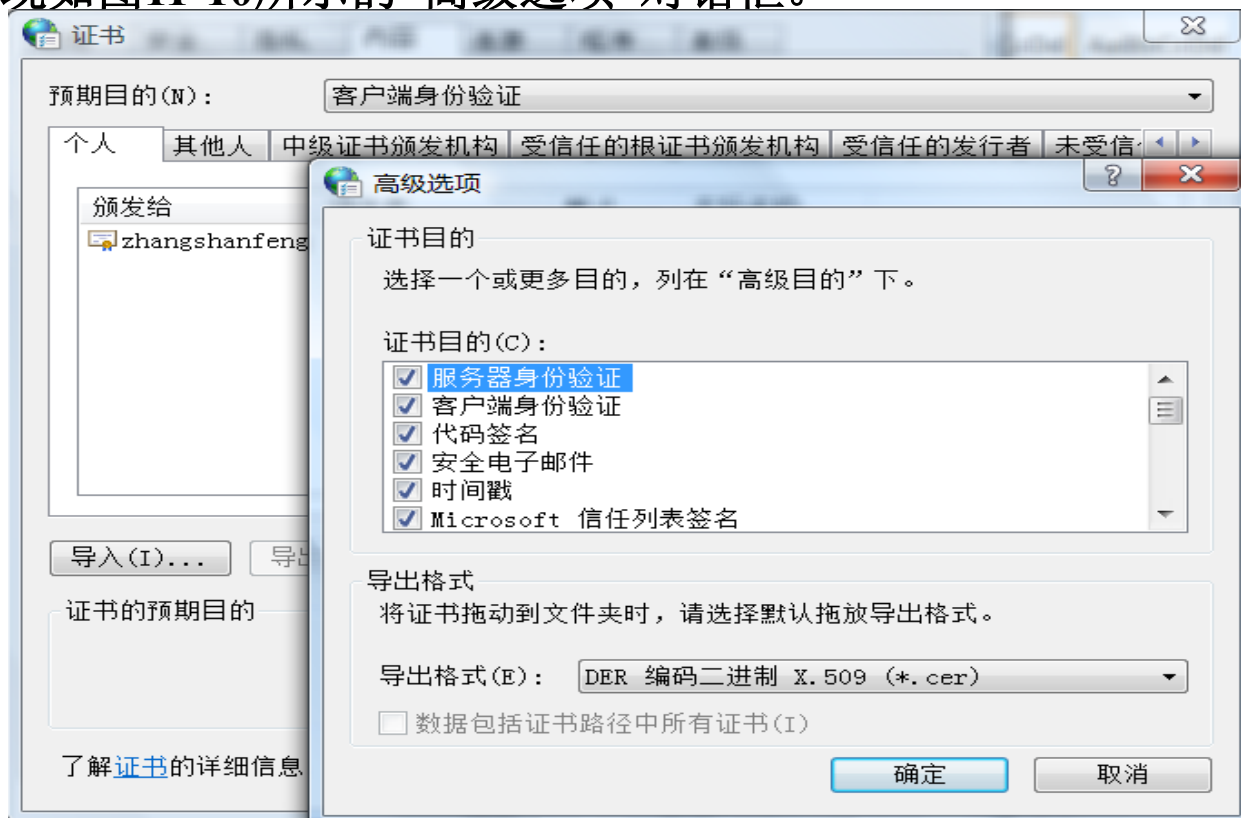


图11-10 Windows“证书”及“高级选项”对话框

11.3 构建基于SSL的Web安全站点

11.3.2 证书服务的安装与管理

2) 在“Windows 组件向导”对话框中单击“下一步”，弹出提示信息对话框，见到如图11-11所示的提示安装证书服务后，计算机名称和域成员身份将不可再改变，单击“是”按钮。

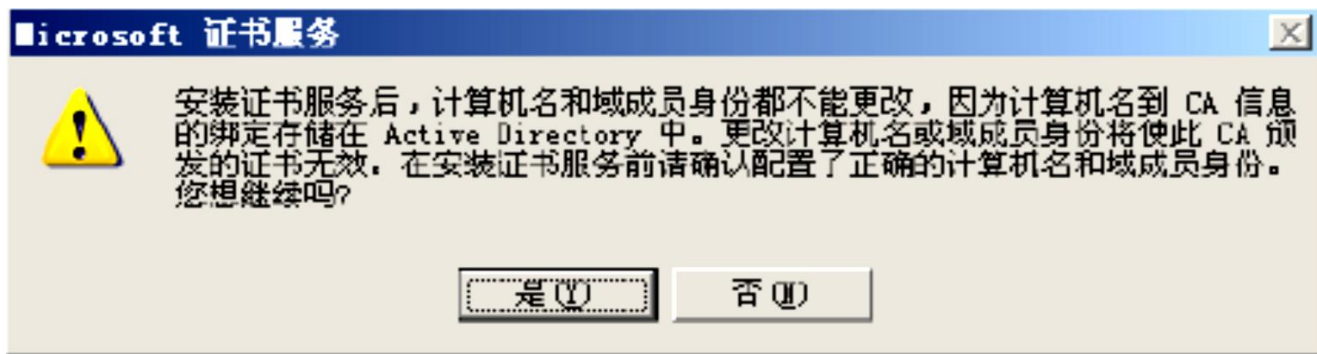


图11-11 安装证书服务的提示信息对话框

☺讨论思考：

- 1) 如何进行基于WEB信息安全通道的构建？
- 2) 证书服务的安装与管理过程主要有哪些？

11.4 电子商务安全解决方案

11.4.1 数字证书解决方案

1. 网络银行系统数字证书解决方案

案例11—5

鉴于网络银行的需求与实际情况，上海市 CA 中心推荐在网银系统中采用网银系统和证书申请 RA 功能整合的方案，该方案由上海 CA 中心向网络银行提供 CA 证书的签发业务，并提供相应的 RA 功能接口，网银系统结合自身的具体业务流程通过调用这些接口将 RA 的功能结合到网银系统中去。



11.4 电子商务安全解决方案

11.4.1 数字证书解决方案

(1) 方案在技术上的优势

1) 本方案依托成熟的上海CA证书体系，采用国内先进的加密技术和CA技术，系统的功能完善，安全可靠；方案中网银系统的RA功能与上海CA中心采用的是层次式结构，方便系统扩充和效率的提高。

2) 网络银行本身具有开户功能，需要用户输入基本的用户信息，而证书申请时需要的用户信息与之基本吻合，因此可在网银系统开户的同时结合RA功能为用户申请数字证书。





11.4 电子商务安全解决方案

11.4.1 数字证书解决方案

(1) 方案在技术上的优势

3) 网络银行具有自身的**权限系统**，而将证书申请、更新和废除等功能与网银系统结合，则可以在用户进行证书申请、更新等操作的同时，进行对应的权限分配和管理。

4) 网银系统可以根据银行业务的特性在**上海CA规定的范围内**简化证书申请的流程和步骤，方便用户安全便捷使用网络银行业务。

5) 该方案采用的技术标准和接口规范都**符合国际标准**，从而在很大程度上**缩短开发周期**，同时也为在网银系统中采用更多的安全方案和安全产品打下良好的基础。

11.4 电子商务安全解决方案

11.4.1 数字证书解决方案

(2) 系统结构框架

银行RA和其他RA的主要职能：

- 1) 审核用户提交的证书申请信息。
- 2) 审核用户提交的证书废除信息。
- 3) 进行数字证书代理申请。
- 4) 完成证书代理更新功能。
- 5) 批量申请信息导入功能。





11.4 电子商务安全解决方案

11.4.1 数字证书解决方案

(3) RA体系

本方案中网银系统下属的柜面终端在接受用户申请输入信息时将数据上传给网银系统，网银整合RA系统直接通过Internet网络连接CA系统，由CA系统签发证书给网银整合RA系统，该系统一方面将证书发放给柜面，使用户获取，一方面将证书信息存储进证书存储服务器。同时该系统还提供证书的查询、更新废除等功能。

RA证书申请、更新与废除过程：

1) RA证书申请。由银行的柜面系统录入用户信息，上传至网银系统和RA系统，在由其将信息传送用户管理系统保存及传送上海CA，由CA签发证书，证书信息回送网银系统和RA系统，由其将证书信息存储用户管理系统并将其发送柜面系统，发放给实际用户。网银系统和RA系统证书申请，如图11-12所示。

11.4 电子商务安全解决方案

11.4.1 数字证书解决方案

(3) RA体系

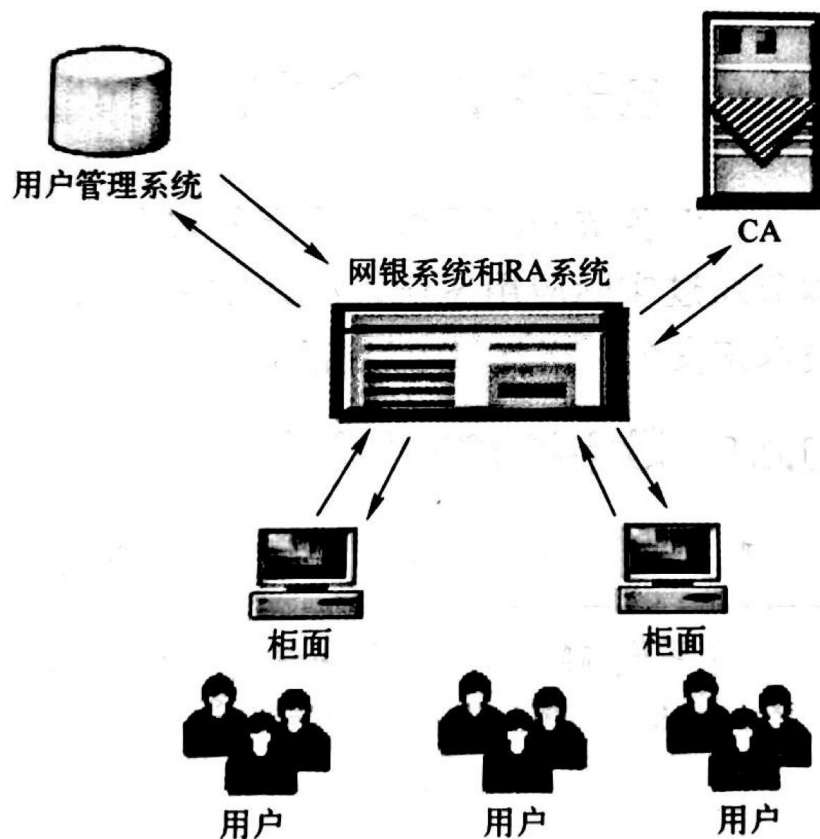


图11-12网银系统和RA系统证书申请



11.4 电子商务安全解决方案

11.4.1 数字证书解决方案

(3) RA体系

2) RA证书更新。证书更新时，由用户提交柜面系统，柜面系统将更新请求传送网银系统和RA系统，由其在用户管理系统中查询到其信息，然后上送上海CA，由CA重新签发证书，回送网银系统和RA系统，再由其将证书信息保存用户管理及发放系统。

3) RA证书废除。证书废除时，由用户向柜面提起请求或网银系统和RA系统处查询到证书过期，将该证书废除，然后由网银系统和RA系统将信息保存用户管理系统。

11.4 电子商务安全解决方案

11.4.1 数字证书解决方案

2. 移动电子商务安全解决方案

随着国内外现代移动通信技术的迅速发展，人们可以借助移动电脑和手机等终端设备随时随地接入网络进行交易和数据交换，如股票及证券交易、网上浏览及购物、电子转帐等，极大地促进了移动电子商务的广泛发展。移动电子商务作为移动通信应用的一个主要发展方向，与Internet上的在线交易相比有着许多优点，因此倍受关注，而移动交易系统的安全是推广移动电子商务必须解决的关键问题。（动态口令认证和双重认证）





11.4 电子商务安全解决方案

11.4.2 USBKey技术在安全网络支付中的应用

随着网络银行和电子支付技术的发展，USBKey 几乎成为网银系统的标配。虽然在小额支付中手机验证码、指纹识别和面部认证等技术的发展也极为迅猛，但USBKey在大额转账安全保障中的权威地位还是无可替代的。USBKey是一种内置微型智能卡处理器，是一种基于 PKI 技术，采用 1024 位非对称密钥算法对网上数据进行加/解密和数字签名，确保网上交易的保密性、真实性、完整性和不可否认性的安全设备。



11.4 电子商务安全解决方案

11.4.2 USBKey技术在安全网络支付中的应用

1. USBKey技术概述

数字证书是带有用户信息和密钥的一个数据文件，保护数字证书本身是PKI体系中最重要的一环之一。数字证书可以保存在诸如光盘、移动硬盘等各种存储介质上，同时满足容易携带、不易损坏和难以被非法复制这些特性，USBKey是数字证书载体是不错的载体。

USBKey作为移动数字证书，它存放着用户的个人私钥信息，并不可读取。而服务提供者（银行、券商等）端记录着用户的公钥信息。当用户尝试进行网上交易时，服务器会向其发送由时间字串、地址字串、交易信息字串和防重放攻击字串组合在一起进行加密后得到的字串，USBKey利用用户的私钥对字串进行不可逆运算得到新的字串，并将字串发送给服务器，服务器端也同时进行该不可逆运算，如果两方运算结果一致便认为用户合法，交易便可以完成。

11.4 电子商务安全解决方案

11.4.2 USBKey技术在安全网络支付中的应用

2. USBKey的安全保障机制

1) 硬件 PIN 码保护

USBKey 采用了以物理介质为基础的个人客户证书，建立基于公钥 PKI 技术的个人证书认证体系（PIN 码）。黑客需要同时取得用户的 USBKey 硬件以及用户的 PIN 码，才可以登录系统。即使用户的 PIN 码泄露，USBKey 没有丢失，合法用户的身份也不会被仿冒，如果用户 USBKey 丢失，其他人不知道用户的 PIN 码，这也是无法假冒合法用户的身份。



11.4 电子商务安全解决方案

11.4.2 USBKey技术在安全网络支付中的应用

2. USBKey的安全保障机制

2) 安全的密钥存放

USBKey 的密钥存储于内部的智能芯片中，用户无法从外部直接读取，对密钥文件的读写和修改都必须由 USBKey 内部的 CPU 调用相应的程序执行，而在 USBKey 接口以外，没有任何方式能对密钥区的内容进行读取、修改、更新和删除，这样可以保证黑客无法利用非法程序修改密钥。



11.4 电子商务安全解决方案

11.4.2 USBKey技术在安全网络支付中的应用

2. USBKey的安全保障机制

3) 双密钥密码体制

为了提高交易的安全,USBKey 采用了**双钥密码体制**保证安全性,在 USBKey 初始化的时候,先将**密码算法程序**烧制在 ROM 中,然后通过产生**公私密钥对**的程序生成一对公私密钥,公钥可以导出到 USBKey 外,而私钥则存储于密钥区,不允许外部访问。进行数字签名时以及非对称解密运算时,凡是有私钥参与的密码运算只在芯片内部即可完成,全程私钥可以不出 USBKey 介质,从而来保证以 USBKey 为存储介质的数字证书认证在安全上无懈可击。





11.4 电子商务安全解决方案

11.4.2 USBKey技术在安全网络支付中的应用

2. USBKey的安全保障机制

4) 硬件实现加密算法

USBKey内置**CPU**或智能卡芯片，可以实现数据摘要、数据加解密和签名的各种算法，加解密运算在**USBKey**内进行，保证了用户密钥不会出现在计算机内存中。

11.4 电子商务安全解决方案

11.4.2 USBKey技术在安全网络支付中的应用

3. USBKey身份认证的系统流程

USBKey身份认证有基于冲击/响应的认证模式和**基于PKI**体系的认证模式两种。

用户在申请 USBKey 时会发行一个**公共密钥**（公钥，publickey）和一个**私有密钥**（私钥，privatekey）。私钥存放在用户的 USBKey 中，公钥保存在银行等发行者端。当发送一份保密文件时，发送方使用接收方的**公钥**对数据加密，而接收方则使用自己的**私钥**解密，服务器端验证用户身份并传输数据的通信流程如下：



11.4 电子商务安全解决方案

11.4.2 USBKey技术在安全网络支付中的应用

3. USBKey身份认证的系统流程

- 1) 客户端通过确认按钮，将信息 A（用户名等）发送给服务器；
- 2) 服务器收到信息 A 后，将信息 A、当前系统时间、随机码序列（为了防止重放攻击）形成的数据 B 保存在服务器上，并通过服务器的加密函数将上述信息以用户公钥加密的方式加密成数据 C 发送给客户端；
- 3) 客户端收到该加密数据 C 后，用自己的私钥解密，再用服务器公钥加密后，形成数据 D 发还给服务器；
- 4) 服务器收到数据 D 后，用自己的私钥解密，并与服务器上原先保存的数据 B 进行比对，若完全一致，则服务器认为请求者是合法用户，允许用户的登录操作。

☺讨论思考：

- 1) **USBKey**是如何保证用户认证过程的真实性？
- 2) 简述服务器端验证用户身份并传输数据通信流程。

*11.5 AI技术在电子商务中的安全应用

人工智能技术正在给电子商务带来颠覆性的变革，诸如视觉搜索与图像识别、产品推荐、美工美图和智能助手等领域已经在电子商务中得到了广泛的应用。与此同时，用来守护系统安全的AI和用来攻击系统安全的AI也都相继出现。从利用AI强化系统安全为出发点，结合利用AI强化系统安全和AI可能被恶意攻击的一些特征来综合分析AI在电子商务安全中的应用。



11.5 AI技术在电子商务中的安全应用

*11.5.1 AI在防范网络攻击中的应用

1. 检测病毒和恶意软件

AI 利用大数据学习恶意软件与正常软件的**不同行为举止**，从而用来判断执行中的软件行为更接近哪一种，利用这个特征来检测恶意软件和病毒。和传统的防护软件利用**恶意软件程序代码的特征库**来判断相比，AI 技术进行**自我学习和进化**，能够对未知病毒或变种进行有效鉴定，且形成云端联动，及时更新共享、人机共智，提高检测的有效性，更适用于对未知有害软件的防范。由于机器学习、神经网络等人工智能技术所具有的**泛化能力**，通过使用已知样本进行训练就可以在未知样本集达到很好的效果。



11.5 AI技术在电子商务中的安全应用

*11.5.1 AI在防范网络攻击中的应用

2. 日志的监视和解析

在企业 IT 运维过程中，一项重要的工作就是对产生的海量日志进行**监控和解析**，AI 利用**大数据的分析技术**，学习正常访问和恶意访问时的特征，用来判断受到的访问是否有攻击性。这种通过分析日志来判断攻击行为的工作，过去通常都是只有少数安全专家凭借经验才能做到，而 AI 则可以拥有和专家相似甚至更高的**准确度**，却没有安全专家昂贵和人力成本和数量紧缺的限制，可以有效解放对高层次安全专家的依赖性。



11.5 AI技术在电子商务中的安全应用

*11.5.1 AI在防范网络攻击中的应用

3. 对用户的持续认证

通常购物平台等系统的认证都是在最初用户进入系统时通过密码、指纹和面部识别等方式进行认证，认证通过后就认为是用户本人，可以进行各种操作。而事实上通过 **session劫持**，**或者直接操作别人忘记退出的系统界面**进行非法操作的行为也多有发生，这种情况下就需要持续认证的登场。持续认证不仅在初始进入系统时，而是**在整个用户访问过程中**，利用用户的IP 地址、访问时刻、所处位置、常用的操作习惯、浏览内容，甚至是鼠标的运动轨迹和打字速度等信息来判断当前的用户和初始用户是不是同一个人，是否存在异常的举止，从而及时提醒用户采取防范措施，或者直接从系统控制端上采取措施限制非法入侵来保护用户。

6.3 访问控制技术

6.3.2 访问控制的模型和分类

(5) 基于属性的访问控制 (ABAC)

下一代访问控制模型

UCON (Usage control) 模型的访问流程包括以下步骤:

访问请求: 访问请求是主体 (用户、程序、设备等) 向系统请求对资源进行操作的行为。访问请求包含主体标识、资源标识、操作类型以及其他访问上下文信息 (如时间、位置、设备状态等)。

上下文获取: 系统获取访问请求所需的上下文信息, 包括当前的环境条件、主体的属性和行为历史等。

访问控制决策、决策结果、访问控制调整、记录与审计、执行访问操作。

整个UCON模型的访问流程是一个动态的过程, 在访问过程中可以根据实时的访问上下文和决策结果进行调整和控制。这种实时的、动态的访问控制机制能够更好地适应复杂的访问需求和变化的环境条件。

11.5 AI技术在电子商务中的安全应用

*11.5.2 防范利用AI及面向AI的安全攻击

从某种意义上看，AI是一把双刃剑，既然它可以用来强化系统安全，也有可能被用来威胁系统安全。只有了解可能被攻击的方式和方法，才能更好地防范和瓦解这些攻击。下面就介绍常见的一些利用 AI和针对 AI的攻击方式。

1. 防范模仿人类行为的AI攻击

随着AI技术的进步，在不同领域突破图灵测试的AI已经不是幻想，Google I/O 2018大会最后一日，Alphabet新任董事长John Hennessy表示：在预约领域，他们开发的AI已经通过了图灵测试。也就是说网络或电话的另一端是人还是AI已经难于区分。生活中最常见的一个例子就是成千上万的骚扰电话就是通过AI拨打的。另外通过图像识别、声音识别突破网络认证，实施网络攻击的其他例子也比比皆是。

防范这类危险的有效方法是通过大数据标记这些有可能包含诈骗行为的电话号码、网络机器人和非法IP地址等，**运营商、用户和第三方安全厂商三位一体**，共同抵御防范这类安全风险。



11.5 AI技术在电子商务中的安全应用

*11.5.2 防范利用AI及面向AI的安全攻击

2. 防范AIF攻击 (AI Fuzzing)

Fuzzing 本来是指专业测试人员通过将无效、意外或半随机的数据注入系统接口或程序，然后监视系统的崩溃、未预期的跳转及潜在的内存泄漏等事件来发现系统的**普通漏洞**和**零日漏洞**（zero-day，又称零时差攻击，是指被发现后立即被恶意利用的安全漏洞）。由于这种操作需要大量专业知识及时间和智能成本，网络犯罪分子并不经常使用 Fuzzing 来发现漏洞。但 AI 的出现大大降低了这种成本。网络犯罪分子开始利用机器学习增强的自动化 Fuzzing 程序，这样他们能够加速发现零日漏洞，导致针对不同程序和平台的零日攻击增加。



11.5 AI技术在电子商务中的安全应用

*11.5.2 防范利用AI及面向AI的安全攻击

2. 防范AIF攻击 (AI Fuzzing)

由于难以预测和防御完全未知的攻击，因此这种发展方向可能带来网络安全的重大安全隐患。攻击者只需要简单的知识就能够开发和训练 Fuzzing 程序，用以自动化和加速发现零日攻击。然后只需将 AIF 应用程序指向目标，就可以开始自动挖掘以进行零日攻击。

完全同样的技术可以用来早期发现系统的漏洞，因此比犯罪分子抢先找到漏洞并补救攻击。

11.5 AI技术在电子商务中的安全应用

*11.5.2 防范利用AI及面向AI的安全攻击

3. 防范Deepfake攻击

Deepfake 是深度学习和赝品（**fake**）的合成词，是指利用**AI合成高度逼真的画像、音声和影像技术**。这其中有一种被称为 **GAN**（生成对抗网络）的新兴技术被广泛应用，通过将两个神经网络的对抗作为训练准则，可以自动生成图像，包括自动篡改图像。早在 **2015** 年，**GAN** 就被用于制作教皇表演“抽桌布”戏法的假视频，由于过于逼真，很快就火遍网络。利用这种技术合成的声音或图形往往能够以假乱真，诈骗组织或犯罪分子通常用来行骗或散布谣言、左右舆论，最终得逞的可能性极大。

而在电子商务中，购物网站上的机器人水军已经很成规模，很多商品评价已经由机器自动生成，不再需要雇人“灌水”。大量虚假评价的涌入，甚至不需要做到以假乱真，就能将真实评价淹没。



11.5 AI技术在电子商务中的安全应用

*11.5.2 防范利用AI及面向AI的安全攻击

3. 防范Deepfake攻击

针对这种攻击，专家正在探索的**基于深度学习的抗编辑视频水印技术**是一种有效的防范技术。这种技术要求水印在视频中是隐藏着的，不能够被编辑，人工智能的深度学习技术被用来嵌入这些数字水印。一旦有了这种水印，图像声音等是否被非法修改就可以通过水印的完整性来简单确认。

除了技术手段外，**广泛宣传、强化认知、多渠道确认和不盲目传播**等素质教育手段也是防止这种攻击的有效手段。



11.5 AI技术在电子商务中的安全应用

*11.5.2 防范利用AI及面向AI的安全攻击

4. 防范数据投毒攻击

数据投毒攻击是被广泛认知的一种面向 AI 的攻击手法。当前机器学习、深度学习等人工智能算法严重依赖于用于训练数据的质量，如果攻击者改变用于学习的数据样本，向人工智能系统发起“投毒攻击”，就可能造成**人工智能系统底层模型**的错误。而基于这种数据学习出来的人工智能系统就会对真正的恶意攻击视而不见，听之任之。要使这种攻击方法成立，往往攻击者会构筑和防御者一样的人工智能系统，**有针对性地诱导**系统做出有利于攻击者的选择。▶

为了防范这类攻击，除了对于学习数据的严格管理外，对于使用 **AI** 模型算法的严格保密也必不可少，因为公开的算法和模型往往更容易招致攻击和入侵。

11.5 AI技术在电子商务中的安全应用

*11.5.2 防范利用AI及面向AI的安全攻击

5. 防范模型提取攻击

模型提取攻击是另一种针对机器学习的攻击手法，在此攻击中，具有黑盒访问但没有ML模型参数或训练数据的先验知识的对手旨在窃取模型的功能。模型提取攻击示意图如图11-13。

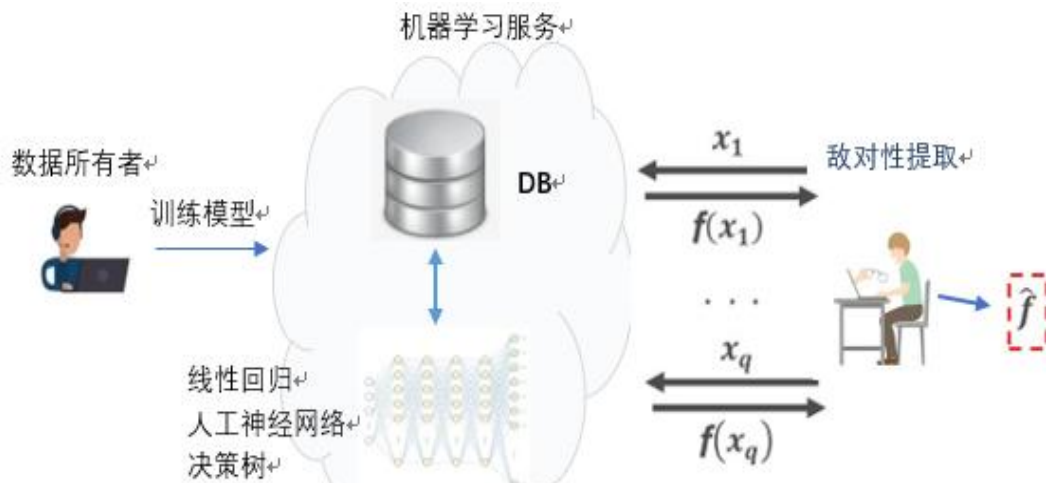


图11-13 模型提取攻击示意图

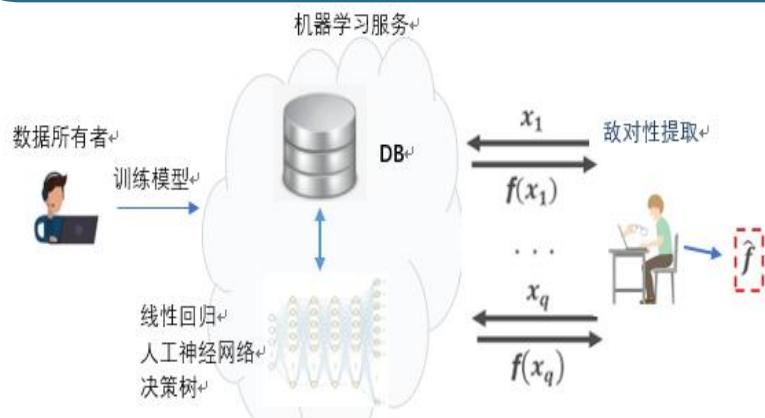
11.5 AI技术在电子商务中的安全应用

*11.5.2 防范利用AI及面向AI的安全攻击

5. 防范模型提取攻击

针对数据所有者提供的机器学习模型，攻击者通过黑盒访问的方式最终取得/函数的详细内容。通过一系列的输入数据，得到各输出数据。根据这些输入/输出数据解开模型内部的逻辑结构，从而实现机器学习模型的复制。

根据机器学习模型输出值的不同，作者提出了几种不同的攻击方式，其中在数据模型给出数据分类和可信度(概率)的情况下，解方程攻击法的原理为：根据给出的数据分类数可以知道数据的模型。



☺讨论思考：

- 1) AI在防范网络攻击中的应用方式有哪些？
- 2) Deepfake攻击的主要基本原理是什么？
- 3) 人类应如何从认知的层面缓解AI威胁？

图11-13 模型提取攻击示意图

11.6 电子商务中物联网设备的安全问题与防范

案例11-7

物联网的攻击：根据CNCERT监测数据，自2022年06月1日至30日，共捕获物联网恶意样本486,620个，发现活跃的僵尸网络服务器地址4,083个，其地址位置主要分布在美国38.8%、中国8.5%、俄罗斯7.5%等国家。针对物联网的网络攻击主要使用密码爆破、漏洞利用等方式进行感染和控制设备，根据CNCERT监测分析，本月发现607类活跃的物联网在野漏洞攻击，发现针对的物联网设备在野漏洞攻击行为14亿307万次，发现活跃的被感染僵尸节点IP有1,703,631个。

11.6 电子商务中物联网设备的安全问题与防范

11.6.1 物联网的发展状况

物联网 (Internet of Things), 是互联网、传统电信网等信息承载体, 让所有能行使独立功能的普通物体实现互联互通的网络。由连接到互联网的所有日常设备组成, 这些设备相互通信并共享数据。这类设备给我们的生活带来极大便利, 也为电子商务发展带来巨大商机。电子商务零售商没有传统零售商那样与顾客面对面沟通的好处, 但连网设备可以使电子商务零售商有机会直接接入到顾客家庭生活的每一个角落。越来越多的智能设备正在彻底改变商业运营模式。



11.6 电子商务中物联网设备的安全问题与防范

11.6.2 IOT设备面临安全风险的种类和特征

1. IOT设备面临安全风险的种类

- 1) 不安全的通信链路+
- 2) 数据泄露+
- 3) 软件漏洞+
- 4) 恶意软件感染+
- 5) 服务中断或停止+



11.6 电子商务中物联网设备的安全问题与防范

11.6.2 IOT设备面临安全风险的种类和特征

2. IOT设备的安全问题特征

- 1) 威胁范围广，受害面大+
- 2) IOT 设备使用期限长久+
- 3) IOT 设备难以监视+
- 4) 难以预测的接入设备+



11.6 电子商务中物联网设备的安全问题与防范

11.6.3 确保IOT设备安全的对策

1. 终端用户应采取的对策

- 1) 选择有全面系统支持和良好安全记录的产品和供应商⁴¹
- 2) 根据说明书进行认真的初期设置和定期对设备进行点检, ⁴¹
不使用默认密码⁴¹
- 3) 不使用时随时关闭设备电源⁴¹
- 4) 更换设备时彻底删除设备中的用户信息⁴¹



11.6 电子商务中物联网设备的安全问题与防范

11.6.3 确保IOT设备安全的对策

2. 厂商及产业管理部门应采取的对策

- 1) 通过制定安全标准及最佳实践引导等方式提高 IoT 产品自身安全性
- 2) 为了能够在设备发生安全问题时能够迅速查明原因和找出对策，设备自身应该保留足够的日志等操作记录，企业应该提供有力的支持指导
- 3) 通过检测认证、实时监测、定期评估等手段提高 IoT 应用的安全防护能力，指导用户选择安全性能好的产品
- 4) 建立强有力的信息共有机制，发生问题后迅速公开问题及对策，避免损失扩大化

☺讨论思考：

- 1) IOT设备面临哪些常见的主要安全风险？
- 2) 为确保IOT设备安全终端用户需要哪些对策？

11.7 本章小结

本章小结

本章主要介绍了**电子商务安全**的**概念**、**电子商务的安全问题**、电子商务的**安全要求**、电子商务的**安全体系**、**AI技术**在电子商务中的安全应用的及**IOT设备的安全防范**等安全问题。着重介绍了保障电子商务的安全技术、网上购物安全协议**SSL**、安全电子交易**SET**，并介绍了**电子商务身份认证证书**服务的安装与管理、Web服务器**数字证书的获取**、Web服务器的SSL设置、**浏览器数字证书的获取与管理**、浏览器的SSL设置及访问等，最后介绍了**电子商务安全解决方案**和**AI技术**在电子商务中的安全应用及**IOT设备的安全防护**。



实验11 用工具抓包分析网络安全

11.8.1 实验目的

本试验将学习Wireshark解析工具的使用，并抓包分析SSL协议的三次握手，给电子商务应用网站开发和运营者提供一些网络安全上的指引。

本实验的主要目的有以下3个：

- 1) 学习解析工具Wireshark的使用过程和方法。
- 2) 学习Wireshark具体检测结果的解读和分析。
- 3) 加深对网站各种安全威胁的认识和理解。



实验11 用工具抓包分析网络安全

11.8.2 实验要求及注意事项

1. 实验设备

本实验需要安装有Windows 10操作系统的电脑。

2. 注意事项

1) 预习准备

由于本实验中使用的软件大家可能不太熟悉，可以提前查找资料对这些软件的功能和使用方法做一些学习，以实现
对试验内容的更好理解。

2) 注意弄懂实验原理、理解各步骤的含义

对于操作的每一步骤要着重理解其原理，生成的评估报告要着重理解其含义，并理解产生这种评估结果的原因。

实验用时：2学时（90-120分钟）

实验11用工具抓包分析网络安全

11.8.3 实验内容及步骤

实验内容主要包括下载安装解析工具、分析SSL三次握手过程四个步骤，下面将分步进行说明。

1. 下载和安装检测工具

该软件是一款开源软件，可以到下述网站下载该软件。下载后按软件提示安装即可。

<https://www.wireshark.org/#download>

2. 分析SSL三次握手过程

选择需要捕获的网卡，点击“捕获”菜单，选择开始，进行数据包的捕获。



实验11用工具抓包分析网络安全

11.8.3 实验内容及步骤

The image shows the Wireshark network traffic capture interface. The top menu bar includes File (F), Edit (E), View (V), Go (G), Capture (C), Analyze (A), Statistics (S), Tools (T), and Help (H). The toolbar contains icons for starting/stopping capture, saving, opening, and other functions. The main display area is divided into three panes:

- Packets List:** A table showing captured packets with columns for No., Time, Source, Destination, and Protocol. The selected packet is 15847, which is a TCP packet from 240e:e1:a802:bb::2c to 2409:8a1e:2899:f770:5806:1fcb:5ed4:3ba1.
- Packet Details:** A tree view showing the structure of the selected packet. It includes Ethernet II, Internet Protocol Version 4, User Datagram Protocol, and Data (146 bytes).
- Packet Bytes:** A hex dump of the packet data, showing the raw bytes in hexadecimal and their ASCII representation.

The status bar at the bottom indicates the capture is in progress on the Intel(R) 82579LM Gigabit Network Connection (以太网). It also shows the current filter is empty, the capture is live, and the configuration is Default.

图11-14 选择wireshark的捕获画面

实验11用工具抓包分析网络安全

11.8.3 实验内容及步骤

客户端向服务器发起的Client Hello消息，客户端将自己所支持的TLS版本都列在了Client Hello中。

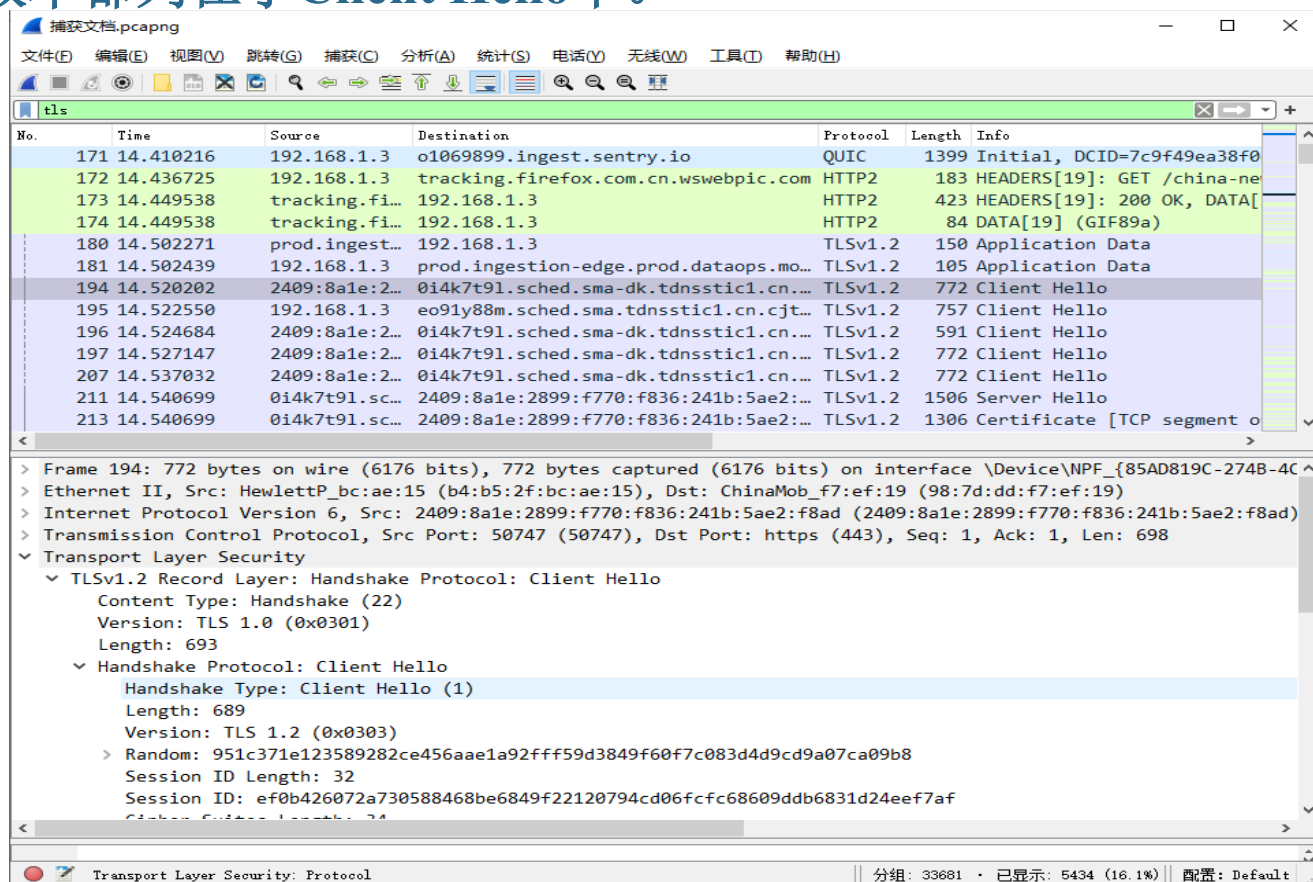


图11-15 第一个SSL握手信息

实验11用工具抓包分析网络安全

11.8.3 实验内容及步骤

(2) 第二个SSL握手 Server开始回复客户端Server Hello。

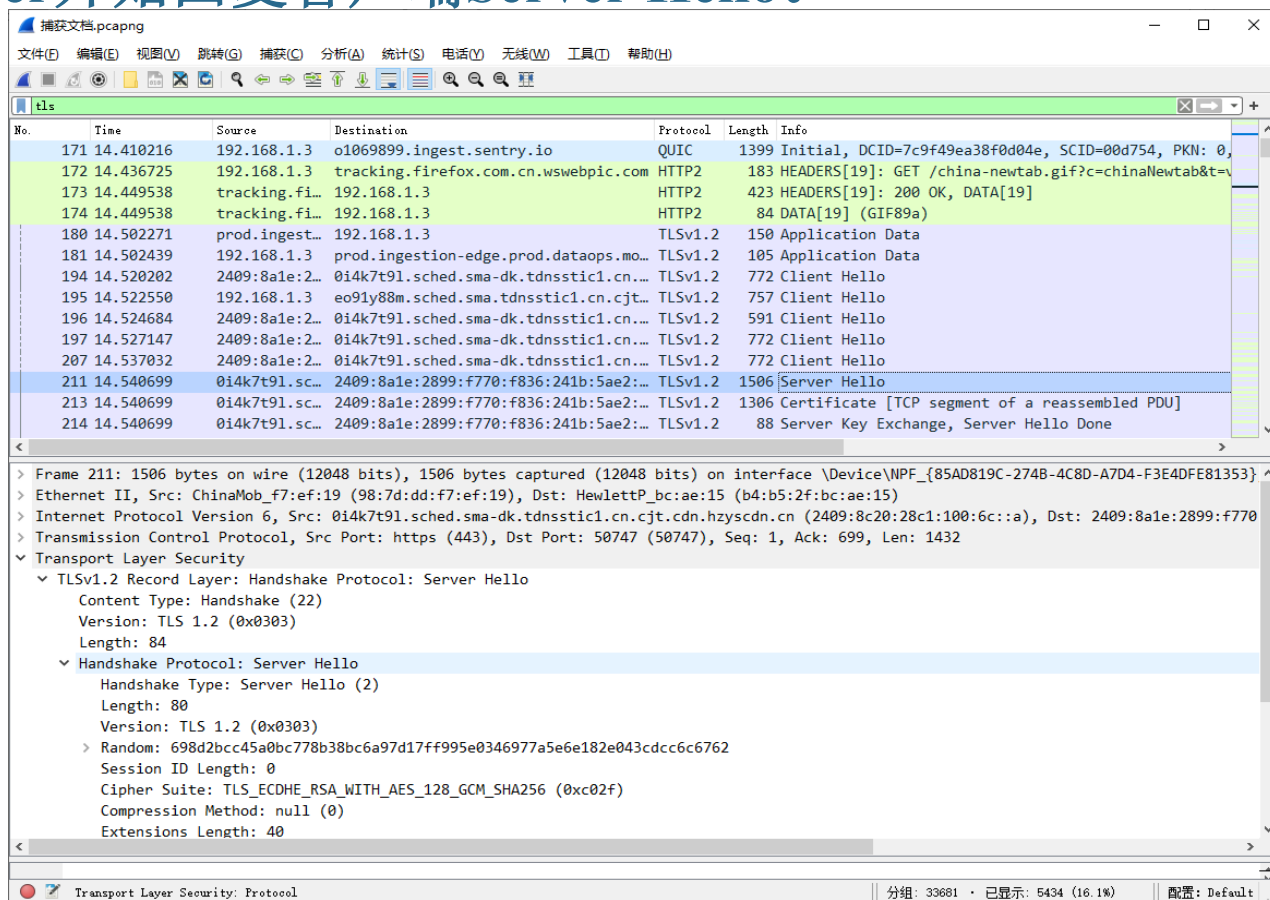


图11-16 第二个握手SSL握手信息

实验11用工具抓包分析网络安全

(3) 第三次握手

Server Hello后,服务器发一个证书.客户端拿到证书做验证.验证后生成一个本地随机密码,并且把密码发给服务器.告诉服务器,后面报文开始加密。

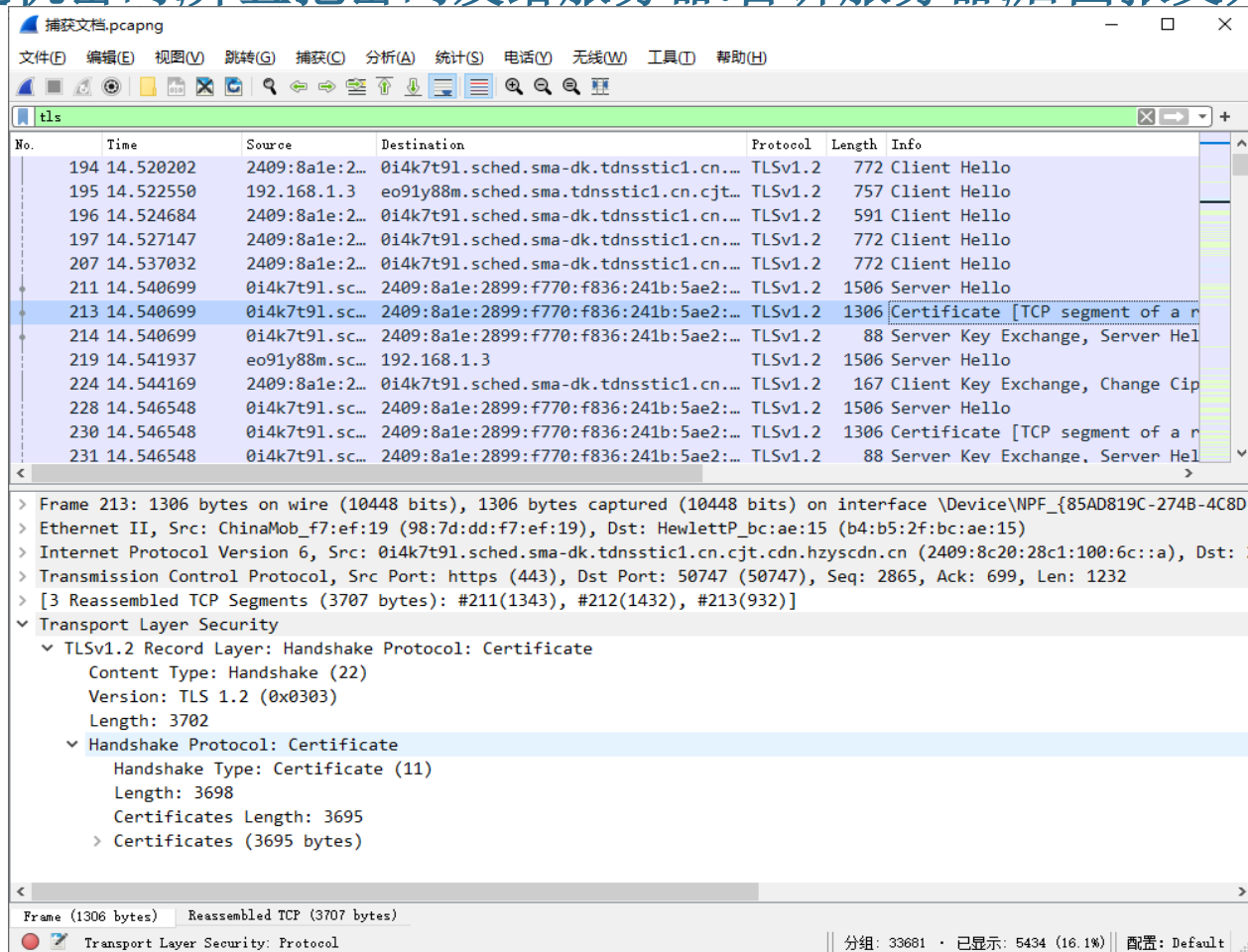
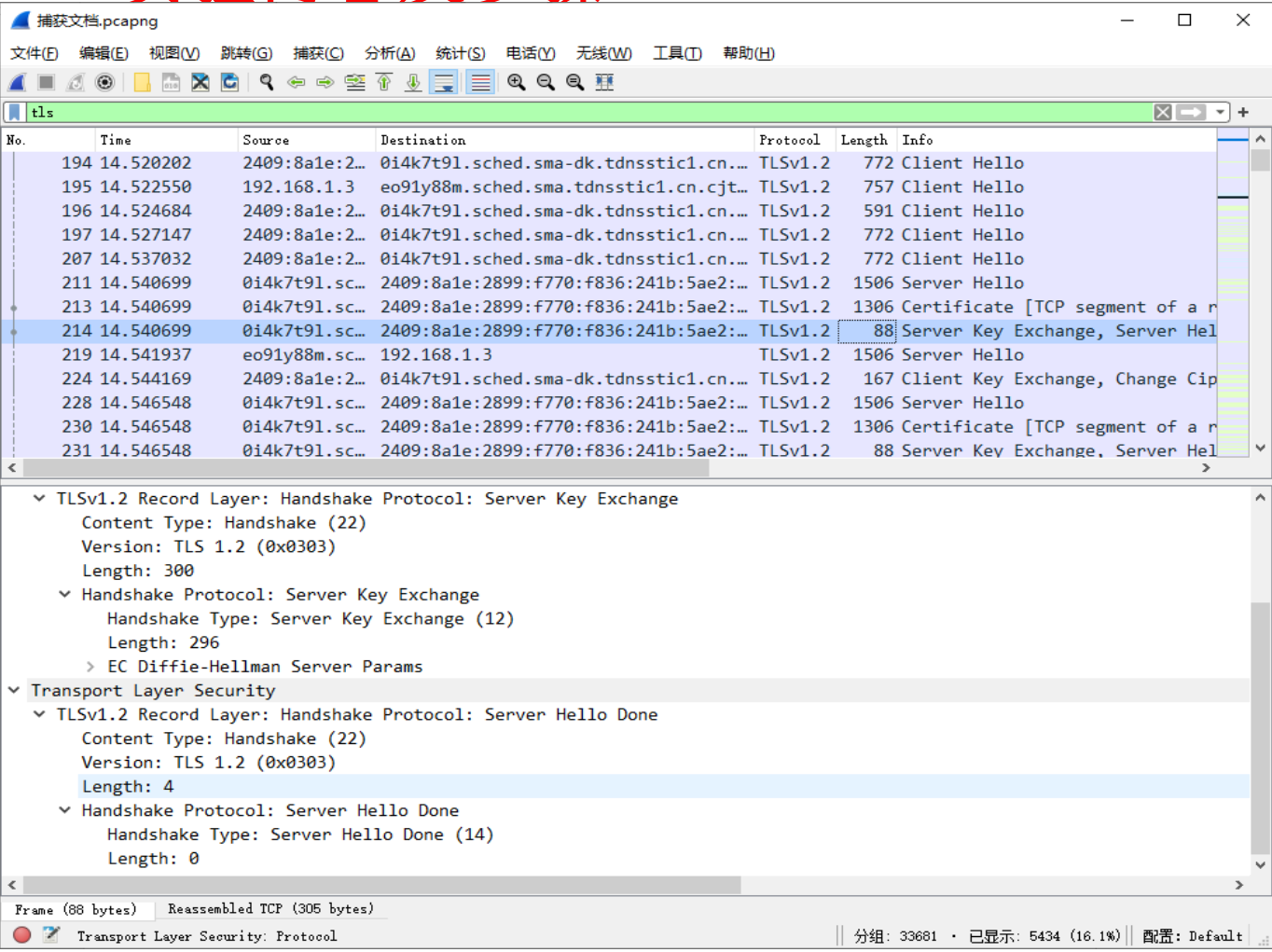


图11-17 服务器发送证书界面

实验11用工具抓包分析网络安全

11.8.3 实验内容及步骤



The image shows a Wireshark packet capture window titled "捕获文件: pcapng". The packet list on the left shows several TLSv1.2 packets. Packet 214 is selected, showing details for "Server Key Exchange, Server Hello Done". The details pane on the right shows the following structure:

- ▼ TLSv1.2 Record Layer: Handshake Protocol: Server Key Exchange
 - Content Type: Handshake (22)
 - Version: TLS 1.2 (0x0303)
 - Length: 300
 - ▼ Handshake Protocol: Server Key Exchange
 - Handshake Type: Server Key Exchange (12)
 - Length: 296
 - EC Diffie-Hellman Server Params
- ▼ Transport Layer Security
 - ▼ TLSv1.2 Record Layer: Handshake Protocol: Server Hello Done
 - Content Type: Handshake (22)
 - Version: TLS 1.2 (0x0303)
 - Length: 4
 - ▼ Handshake Protocol: Server Hello Done
 - Handshake Type: Server Hello Done (14)
 - Length: 0

The status bar at the bottom indicates "Frame (88 bytes) | Reassembled TCP (305 bytes) | Transport Layer Security: Protocol | 分组: 33681 · 已显示: 5434 (16.1%) | 配置: Default".

图11-18 验证随机密码画面

“十三五”国家重点出版规划
国家自然科学基金项目资助

上海市普通高校优秀教材奖
上海高校精品/优质在线课程

诚挚谢意！

网络安全技术及应用

国家智慧教育平台

国家智慧教育平台—上海精品/优质在线课程

(第5版. 慕课微课版立体化)



网络安全技术